

Security Measure Plan for UNIX and Linux Operating Systems

Version 3.7
2016-11-30
Restricted

Restricted
Document Owner: Siemens Governance Information Security and
Product & Solution Security
governance.infosec_pss@siemens.com
Siemens AG, CT RDA SEG
Otto-Hahn-Ring 6
81739 Munich
Germany

Edited by: Christian Koepp, Nilss Lode
Siemens AG, CT RDA ITS CER
Otto-Hahn-Ring 6
81739 Munich
Germany

Please write your comments to governance.infosec_pss@siemens.com.
© 2016 by Siemens AG

Table of Contents

1	Document Release and History	5
1.1	Document Release	5
1.2	Document History	5
1.3	Changes in Version 3.7	6
1.4	Document Maintenance	7
2	Introduction	8
2.1	Applicability and Scope	8
2.2	Requirement Level Definition	9
2.3	Categorization of Measures	9
2.4	Readability	10
2.5	Regulatory and Corporate Obligations	11
3	General	12
3.1	Physical Security	12
3.1.1	Protecting physical interfaces	12
3.1.2	BIOS Settings - Boot and BIOS Passwords	13
3.1.3	Boot Sequence, Multi Boot	15
3.1.4	Prevent unauthenticated Boot	17
3.1.5	Secure Built-in Remote Management Interface	19
3.1.6	Protecting Linux Bootmanager with password	21
3.1.7	No Biometric Authentication Devices	24
3.1.8	Disable Firewire (IEEE1394)	25
3.2	Installation and Maintenance	27
3.2.1	Operating system version	27
3.2.2	Applying security patches	28
3.2.3	Siemens CERT Security Telegrams	31
3.2.4	Install Corporate Scan Service Software Agent	33
3.3	Local Security	34
3.3.1	Enable Stack Protection	34
3.3.2	Enable link protection	36
3.3.3	Disable Core Dumps	37
3.3.4	Protect Single User Mode with Password	39
3.3.5	Setting Umask	41
3.3.6	Scheduled service security	43
3.3.7	Protecting System Files	45
3.3.8	Home folders	47
3.3.9	Links in the folder /tmp	49
3.3.10	Existing user and group for all files	50
3.3.11	Monitoring SUID and SGID files	51
3.3.12	Disable Automount and Autorun	52
3.3.13	Preventing shutdown without login	53
3.3.14	Secure Configuration Files	55
3.4	Malware Protection	56
3.4.1	Standard Virus Scanner	56
3.4.2	Special Virus Scanner	58
3.5	Network Security	60
3.5.1	Check active Network Connections	60

3.5.2	Disable Unneeded Network Protocols	62
3.5.3	Securing Bluetooth	63
3.6	Account and Access Control	64
3.6.1	Concept of Least Privileges for Users	64
3.6.2	Assigning and setting up accounts	67
3.6.3	Built-in IDs	72
3.6.4	Deactivating guest IDs	73
3.6.5	Automatic Logon	74
3.6.6	Password-protected screensavers	75
3.7	Logging	77
3.7.1	Activating and evaluating logs	77
4	Services	79
4.1	General	79
4.1.1	Disable all Unnecessary Services	79
4.2	Base Services	80
4.2.1	Disable 'R' daemons and Telnet daemon	80
4.2.2	Secure Rsync	82
4.2.3	Secure NIS	83
4.2.4	Secure Internet Daemon	85
4.3	SSH	87
4.3.1	Secure SSH Server	87
4.3.2	Use strong cryptographic algorithms	90
4.3.3	Requirements for SSH keys	91
4.4	NTP	93
4.4.1	Time Synchronization	93
4.4.2	Network Time Protocol Daemon	95
4.5	SNMP	96
4.5.1	Secure SNMP Server	96
4.6	Mail Transfer Agents	98
4.6.1	Secure Mail Transfer Agent Daemon	98
4.7	IMAP and POP3 Server	101
4.7.1	Secure IMAP and POP3	101
4.8	Webserver	102
4.8.1	Protecting Web Server	102
4.9	NFS and RPC	104
4.9.1	Configure NFS	104
4.10	Samba	106
4.10.1	Secure Samba Server	106
4.10.2	Configure Samba Server in Active Directory Environment	109
4.10.3	Avoid the Samba Web Administration Tool (SWAT)	110
4.11	FTP	111
4.11.1	Configure FTP Daemon	111
4.11.2	Secure Anonymous FTP	112
4.12	X Server	114
4.12.1	Restricting X Server Access	114
5	Checklist	116
	References	120

1 Document Release and History

1.1 Document Release

This document is classified as "Restricted". Version 3.7 has been given the status "released".

	Name	Operating Group	Date
Author	Christian Koepp, Nilss Lode	CT RDA ITS CER	2016-11-30
Reviewer	Matthias Dominick	CT RDA SEG	2016-11-30
Release Governance Information Security		CT RDA SEG	2016-11-30

1.2 Document History

Version	Name	Operating Group	Date
3.3	Dr. Johann Uhrmann Thomas Schreck	CT RTC ITS CCS-DE	2013-05-31
3.4	Dr. Johann Uhrmann	CT RTC ITS CCS-DE	2013-11-30
3.5	Dr. Johann Uhrmann	CT RTC ITS CER-DE	2015-05-31
3.6	Dr. Johann Uhrmann Nilss Lode	CT RDA ITS CER-DE	2016-05-31
3.7	Christian Koepp Nilss Lode	CT RDA ITS CER-DE	2016-11-30

1.3 Changes in Version 3.7

The following changes occurred in this version of the document:

Changes to the introduction:

- Updated list of supported platforms
- Added note to see CERT website for latest up-to-date version of supported platforms

New measures:

- Measure 3.2.4 (M447301): Install Corporate Scan Service Software Agent
This change was submitted after the review phase: EVAL period prolonged to 2017-06-30.
- Measure 3.3.14 (M447647): Secure Configuration Files
- Measure 3.4.2 (M447203): Special Virus Scanner
This change was submitted after the review phase: Rewrote *Measure* and *Exception* part to precise measure.
- Measure 4.4.2 (M447886): Network Time Protocol Daemon
This change was submitted after the review phase: Reworded measure to include disabling of NTP suites as well.

Updated measures:

- Measure 3.3.6 (M608700): Added systemd implementation details. Renamed title to cover all scheduled services.
This change was submitted after the review phase: Precised *Measure* section.
- Measure 3.3.7 (M802906): Added systemd implementation details.
- Measure 3.3.8 (M406350): Changed root home folder rights to 750, EVAL flag set.
- Measure 3.3.9 (M805036): Added exception as measure is actually part of Measure 3.3.2 (M447734) on systems running on recent kernel versions, no need to set EVAL.
- Measure 3.3.10 (M509730): Added exception for chroot jails. Rewrite of exception for hosts with shared file systems. Switched to path-based exceptions instead of host-wide ones.
- Measure 3.3.12 (M809740): Added systemd implementation details.
- Measure 3.4.1 (M250305): Minor title change. Complete rewrite in cooperation with the Virus Competence Center.
- Measure 3.5.1 (M202900): Fixed typo in measure section, no need to set EVAL.
- Measure 3.5.2 (M307609): Fixed typo in measure section, no need to set EVAL.

- Measure **3.7.1** (M413050): Added systemd implementation details and sealing suggestions. Renamed title to support all common logging solutions. Enforced "persistent" storage of log entries.
- Measure **4.4.1** (M140306): Added systemd implementation details.
- Measure **4.6.1** (M402440): Removed issue affecting only Reliant Unix from implementation section, no need to set EVAL.

1.4 Document Maintenance

Release dates for updates of CERT Measure Plans are the end of May and the end of November of each year. However, CERT Measure Plans will only be updated if significant changes require a new release. Hence, there might not always be a new release of every CERT Measure Plan on every release date. Any update will be announced via a CERT Security Telegram of category "Governance". For a detailed description of the release process see <https://www.cert.siemens.com/rules#process>.

The information herein has been compiled to our best knowledge and testing. To further improve its quality, we depend on your feedback and opinion. Please send any comments or suggestions via e-mail to governance.infosec_pss@siemens.com.

2 Introduction

The “Security Measure Plan for UNIX and Linux Operating Systems” document is a platform specific supplement to the ISEC Technical Standards of the *Siemens Information Security Framework* [1] and other existing Siemens CERT Security Measure Plans. Its purpose is increased intrusion security for IT systems and it must be implemented in all Siemens units. The measures and their priorities described here may be tightened and supplemented as necessary.

The Security Measure Plan is published by Siemens CERT as part of the ISEC Technical Standards of the *Siemens Information Security Framework* [1] on behalf of Siemens Governance Information Security and Product & Solution Security.

To assist in documentation, a checklist (see [Chapter 5](#)) was prepared in addition to the Security Measure Plan. The checklist can be used to document the implementation of the individual measures of this Security Measure Plan.

2.1 Applicability and Scope

The measure plan should be applicable for the different kinds of UNIX/Linux platforms and distributions.

Appliances are separate hardware devices or virtual machines with an integrated firmware or operating system for specific usages. The appliance owner is only able to configure a small subset of the functionality that the device offers but does not have full control of the system. This makes it impossible to fully implement this security measure plan. Examples for such devices are storage appliances, such as NetApp filers.

This security measure plan is not applicable for appliances and therefore does not need to be implemented on those devices. Nevertheless, the *Siemens Information Security Framework* [1] still applies for these devices and must be implemented. If Siemens CERT offers a security measure plan specifically for an appliance, that measure plan must be implemented (and it may require to implement this measure plan as well).

Independent from the applicability, we are only supporting the following operating system versions in the “Implementation” section and with follow-up support according to our CERT supported platform list (https://www.cert.siemens.com/about/supported_platforms):

- FreeBSD stable 9 and 10
- FreeBSD releng 9.3, 10.1, 10.2 and 10.3
- HP-UX 11.31
- Oracle Solaris 10 and 11
- IBM AIX 6.1 and 7.1
- Debian - 7 LTS and 8 LTS
- openSUSE - 13.2
- Ubuntu - 12.04 LTS, 14.02 LTS and 16.04 LTS

- SUSE Linux Enterprise Server 12 and 11SP4
- Red Hat Enterprise Linux 5, 6 and 7
- CentOS - 5, 6 and 7

Please be aware that CERT support ends when a distribution leaves the official, vendor-defined life cycle. Please consult the CERT website for the latest list of CERT supported products.

We would like to thank Frank Steinbach (ATOS) for his support in developing the AIX specific parts of this measure plan.

2.2 Requirement Level Definition

The key words "MUST", "MUST NOT", "REQUIRED", "SHALL", "SHALL NOT", "SHOULD", "SHOULD NOT", "RECOMMENDED", "MAY", and "OPTIONAL" in this document are to be interpreted as described in RFC 2119 (see <https://www.cert.siemens.com/rules/rfc2119>).

2.3 Categorization of Measures

All measures in this document are categorized as **MANDATORY**. This categorization means that implementation is absolutely required. If implementation is impossible, a system must not be connected to the Siemens intranet. Exceptions other than those explicitly declared inside a measure require approval by a CISO-level representative of ISEC (e.g., exceptions for Research & Development purposes).

If a new measure is added or an existing measure is upgraded, it receives the additional flag **EVAL** – with the exception of very time-critical cases. The use of the **EVAL** flag signifies:

'This measure has an evaluation period of three months plus an implementation grace period of one month before it must be implemented on all affected systems. The end date of the evaluation period is clearly stated next to the unique measure number: (e.g., **EVAL** flag expires 2010-01-30). Within the three month evaluation period Siemens units and service providers are requested to pilot this measure and to report any problems to governance.infosec_pss@siemens.com.'

New or upgraded measures without an **EVAL** flag are considered time-critical. Such measures must be implemented within one month after release. Should it turn out – as a result of the three months evaluation period – that the measure cannot be implemented as expected, Siemens CERT will communicate appropriate actions via a Security Telegram of category "Governance". Therefore please check our webpage at <https://www.cert.siemens.com/sectel/gov> to determine whether a measure marked with **EVAL** has not become binding.

2.4 Readability

By default, all measures have the same structure according to heading, measure, explanation and implementation sections:

chapter number	measure name	unique measure number	category	applicability	evaluation flag
3.1.12	Measure name			S, D	EVAL
				mandatory	

Measure Mxxxxxx, created/modified/revised on yyyy-mm-dd.
EVAL flag expires yyyy-mm-dd.

Explanation

<Motivation and background information for this measure>

Measure

<General description of what needs to be done>

Implementation

<Detailed information about how to implement this measure>

Note: The implementation section given for a measure provides guidance for implementation, i.e., it does not prescribe a way in which the measure must be implemented. Alternative implementations that also satisfy the measure therefore are possible.

The applicability of some measures may depend on the physical environment the system is operated in. For this reason, the **applicability** field was introduced. This document describes two different environments, categorized as servers (**S**) and desktop (**D**) systems.

Applicability	Description
S	Systems which are operated in an access controlled physical environment. Typically these systems are servers and are operated in data centers where only authorized persons have access to.
D	Systems which are operated in office environments or mobile devices, e.g., notebooks. Desktop systems are operated in various environments and the risk for unauthorized physical access is higher. This also includes server systems in unprotected environments.

2.5 Regulatory and Corporate Obligations

Regulatory and corporate obligations support achieving contractual and legal compliance but assist as well in the handling of Information Security incidents. While not each obligation may be applicable for every system/application at the time of writing, this may change in the future. Therefore, a web site is listed for every topic to find further information as well as contact persons who can assist you in case of questions.

Please note that the obligations may also apply to virtual systems and applications running on virtualized hardware.

Compliance: Some of the measures mentioned in this document might affect current Compliance regulations, especially regarding the effective circulars concerning the storage of certain compliance-relevant data.

Compliance web site: <https://intranet.siemens.com/en/compliance/>.

Asset Classification & Protection: To protect assets adequately according to their criticality it is necessary to identify these assets based on a standardized process, classify the assets, implement appropriate protection concepts and document this in a central tool (as specified by *Siemens Circular No. 156 [6]*).

This includes all tangible and intangible assets and therefore may also apply to IT Applications and Infrastructure, which are subject of this measure plan. Please note, that if several applications are hosted or run on one server system, the application with the highest criticality determines the criticality of the server system.

GM SEC web site "Asset Classification & Protection (ACP)": <https://intranet.siemens.com/asset-classification/>.

Documentation of the IT landscape: Networks, systems and applications shall be sufficiently documented and kept up to date in the appropriate IT repositories.

If those IT repositories do not apply to a system or infrastructure component or application, at least a documentation of the owner of the infrastructure and owner of the application(s) shall be maintained.

Siemens IT web site "IT Repositories": <https://cio.siemens.com/cms/it/en/governance/Pages/gov-lpd.aspx>.

Inventory Infrastructure "SAM@Siemens": Systems which are supported by the "SAM@SIEMENS" Inventory Tools need to establish a connection to the Inventory Infrastructure "SAM@Siemens" to ensure the compliant handling of license inventory data.

Siemens IT web site "Software Asset Management (SAM)": <https://cio.siemens.com/sam/>.

3 General

3.1 Physical Security

3.1.1 Protecting physical interfaces

D

mandatory

Measure M729001, modified on 2016-04-30.

Explanation

Open communication interfaces (COM, LPT, USB, IR, SCSI, etc.) can be used to exchange data which cannot be controlled with standard authentication and access mechanisms.

Measure

Disable all physical communication interfaces you do not need.

Exception

This measure is not applicable for cloud environments, i.e., on systems without direct console access and without access or implementation of physical ports, BIOS settings, and boot loader settings.

Furthermore, this measure is not applicable on virtualized systems in general.

Implementation

In the case of unused interfaces, either deactivate the physical connections of the communications interfaces, prevent the loading of the corresponding interface drivers or protect the interfaces in the operating system by assigning appropriate authorizations to the device files. This last step is also to be carried out for communication interfaces which are in use, including logical interfaces.

Revision history:

- 2.3: categorized "recommended"
- 3.6: Exception for cloud environments.

3.1.2 BIOS Settings - Boot and BIOS Passwords

D

mandatory

Measure M680620, modified on 2016-04-30.

Explanation

The BIOS setup contains some settings that are security relevant, e.g. boot sequence, boot password, wake-on LAN, system time, etc. Changes to these settings should only be made by the administrator of the system.

This can be achieved by securing physical access to the system, securing management networks or – depending on the system – by setting a BIOS access password. Whereas a BIOS boot password prevents a computer from starting up without providing an additional credential.

Measure

Set a BIOS access password.

Set a computer boot password if there are no strong reasons against it.

NOTE: Since BIOS passwords are not susceptible to brute-force attacks, no password aging policy needs to be implemented.

Use a separate, isolated network for hardware management devices which can access BIOS settings (see Measure 3.1.5 (M700351)). Restrict access to this management network to authorized personnel.

Restrict physical access to the hardware to authorized personnel.

NOTE: This measure does not apply to systems in an access controlled physical environment (see chapter 2.4).

Exception

This measure is not applicable for cloud environments, i.e., on systems without direct console access and without access or implementation of physical ports, BIOS settings, and boot loader settings.

Furthermore, this measure is not applicable on virtualized systems in general.

Implementation

The implementation depends on the specific BIOS version of the particular system. For details on BIOS settings please refer to the manual of the computer or mainboard.

Set a BIOS password or secure the boot sequence and other administrative access to hardware settings by setting up an access controlled physical environment which

- restricts physical access to the hardware to authorized personnel (e.g. use locked server cabinets),

- allows network access to hardware settings only from a separate network. The access to this network has to be restricted to authorized personnel (see Measure **3.1.4** (M338090)).

Revision history:

- 2.3: categorized "recommended"
- 2.5: changed Solaris secure-mode from "full" to "command"
- 3.0: Minor Changes in wording
- 3.2: clarification: no password aging
- 3.3: included management networks and physical access, removed Solaris specific implementation note, replaced exception with note about applicability
- 3.6: Added exception for virtual systems.

3.1.3 Boot Sequence, Multi Boot

D

mandatory

Measure M201280, modified on 2016-04-30.

Explanation

In most cases, security settings of the operating system (OS) of a computer can be easily bypassed by starting this computer with a second OS. Most importantly, it is not possible to control access to files on a system when a second OS is running. This may corrupt the security of your OS.

There are several ways to run a second OS on a computer:

- Boot a second OS from a removable media, e.g., floppy, CD-ROM, Memory-Stick, etc.
- Use a boot manager to run two or more OS but only one at a time on a single computer
- Use virtual machines to run two or more OS simultaneously on a single computer.

NOTE: Virtual machines do not introduce a new risk to the scenario described. Except for the requirement of a BIOS boot password the same rules apply as for multi boot systems.

Measure

It must be ensured that the boot sequence is not adjustable to allow boot from third party mediums (e.g., USB Sticks).

Adjust the boot sequence of your computer so that the system boots from your local hard disk first.

As a default only install one operating system per computer. The following rules are mandatory if you need to deviate and run multiple operating systems on a single machine.

- BIOS Setup password must be set.
- BIOS boot passwords have to be used on multi boot systems.
- Each of the OS on a single machine needs to be configured and secured according to Siemens IS-Rules respective Siemens CERT measure plans.
- Unsupported and insecure OS must never be connected to the Siemens intranet.
NOTE: See also *Siemens Circular No. 133* [7] "Usage of Standard Platforms"
- In case of multi boot, keep each OS on a separate partition and hide partitions of inactive operating systems from being accessed by the current active instance of an OS on a machine.
- All instances with a connection to the Siemens Intranet have to use standardized processes (e.g., GNS identification, etc.), a unique identifier, and they have to be registered in an inventory database.

Exception

This measure is not applicable for cloud environments, i.e., on systems without direct console access and without access or implementation of physical ports, BIOS settings, and boot loader settings. This exception does not apply to virtualized systems with users who can access the boot loader, e.g., if VMware console access is granted to users of the operating system.

NOTE: Measure M449461 of the Security Measure Plan for VMware vSphere 5 [5] is an example for a control which prevents users from accessing the boot loader on virtual systems.

Implementation

Implement topics according to the measure rule.

Revision history:

- 3.0: created measure
- 3.1: BIOS Setup password must be necessary
- 3.1: Removed EVAL flag
- 3.5: references to old Circulars or Corporate Security Policies have been adjusted, minor clarification in the implementation section
- 3.6: Added exception for cloud environments.

3.1.4 Prevent unauthenticated Boot

S

mandatory

Measure M338090, modified on 2016-04-30.

Explanation

Even in server environments Measure 3.1.3 (M201280) applies but it is often necessary to perform multiboot, e.g., to perform recurring administrative tasks. Therefore, unauthorized booting of alternative operating systems must be prohibited.

Measure

It must be ensured that the boot sequence is adjustable only by trusted personal to allow boot from third party mediums (e.g., USB Sticks, network).

Adjust the boot sequence of your computer so that the default system boots from your local hard disk first.

The following rules must be applied when alternative systems are used for administrative tasks, e.g. booting an Oracle Solaris system to run level S:

- BIOS Setup password must be set.
- Each of the OS on a single machine needs to be configured and secured according to Siemens IS-Rules respective Siemens CERT measure plans.
- All instances with a connection to the Siemens Intranet have to use standardized processes (e.g., GNS identification, etc.), a unique identifier, and they have to be registered in an inventory database.

Further administrative interfaces (e.g., Fujitsu Server System Manager) must be protected to only allow trusted personal to adjust boot sequence.

NOTE: Since BIOS passwords are not susceptible to brute-force attacks, no password aging policy needs to be implemented.

Exception

This measure is not applicable for cloud environments, i.e., on systems without direct console access and without access or implementation of physical ports, BIOS settings, and boot loader settings.

Furthermore, this measure is not applicable on virtualized systems in general.

For all other systems, setting a BIOS password is optional, if all of the following criteria are met:

- Use of a separated, isolated network for hardware management devices which can access BIOS settings, see Measure 3.1.5 (M700351). This may be achieved by one of the following:
 - The network interface of the hardware management device must be connected to an isolated network. No other connections to this network exist.

- The network interface of the hardware management device must be connected to a special network. No connections between this network and the Siemens intranet or the internet exist. Access to this special network is logged and restricted to authorized personnel.
- The BIOS settings cannot be accessed from any other network than this management network.
- Access to this management network is restricted to authorized personnel.
- Physical access to the system is restricted to authorized personnel.

Implementation

Implement topics according to the measure rule.

Revision history:

- 3.1: created measure
- 3.2: add note about data centers
- 3.3: BIOS password is optional in secured management networks
added example for administrative task
- 3.4: removed EVAL flag
- 3.5: minor clarification in the implementation section
- 3.6: Added exception for virtual systems

3.1.5 Secure Built-in Remote Management Interface

S,D EVAL

mandatory

Measure M700351, modified on 2016-04-30. EVAL flag expires 2017-08-31.

Explanation

Modern server systems are often equipped with a built-in remote management interface. This interface can typically be used to access (e.g., view screen) and manage (e.g. restart, boot from external media) the system without the need for the main operating system to be running. While this can be very useful for maintenance, these interfaces can allow an attacker to easily take over the system. Therefore, such interfaces have to be sufficiently secured.

The different server system vendors use many different names for these interfaces, including Integrated Remote Management Controller (iRMC – Fujitsu), Integrated Dell Remote Access Controller (iDRAC), HP Integrated Lights Out (iLO), IBM Integrated Management Module, etc.

More generic names are Server Management Board or Intelligent Platform Management Interface (IPMI).

These interfaces are implemented as embedded systems with operating system, web server, user administration and alarm management etc. and are operational even when the server system itself is in standby mode. Communication is carried out via LAN connection, which can be shared with the server system or used exclusively for system management.

Such built-in remote management interfaces typically come with default passwords for the main administrative user account. There is a high risk that an attacker who has access to the Siemens Intranet can easily gain full control over a server if default security configuration has not been adjusted.

Measure

Either ensure that remote management interfaces are disabled / not connected or secure them by following these generic rules:

- Remote management interfaces are connected only to a *separate, isolated management network* (at least a separate VLAN). This requirement is mandated by *Topic-Specific ISEC Policy: Operations Security*, [4] (rule-id 12.1.1-06). Especially, the interface must *never be directly reachable from the Siemens Intranet*.
- For all accounts that grant administrative access to a system the *Topic-Specific ISEC Policy: Access Control*, [2] for Administrators must be followed. Always replace well-known or default passwords.
- Logging must be enabled and monitored to allow for a detailed auditing of all administrative changes to a server system via the built-in remote management interface.
- Always apply the manufacturer's up-to-date security patches for the firmware of remote management interfaces.

- Disable any protocols that use plain text transmission of passwords, e.g., telnet, snmp, http forms.

Exception

This measure is not applicable for cloud environments, i.e., on systems without direct console access and without access or implementation of physical ports, BIOS settings, and boot loader settings.

Implementation

The implementation depends on the specific remote management interface of the particular system and your environment. For details, please refer to the corresponding documentation.

Revision history:

- 3.2: added measure
- 3.3: removed EVAL flag
- 3.4: restriction of management devices to isolated management networks
aligned explanation with other measure plans
application of firmware updates
EVAL flag set
- 3.5: clarification of mandatory rules, moved mandatory parts to the measure section, EVAL flag set
aligned measure with MS Windows Security Measure Plans, references to old Circulars or Corporate Security Policies have been adjusted
- 3.6: Specified isolated network requirements. Added additional examples of protocols using plain text password transmission. Added reference to ISEC policy. Added exception for cloud environments. Prolonged EVAL flag set.

3.1.6 Protecting Linux Bootmanager with password

D

mandatory

Measure M112800, modified on 2016-04-30.

Explanation

A bootloader can be used, among other things, for selecting between several operating systems or kernels on a machine. The most commonly used bootloaders on Linux systems are **LILLO** (Linux **L**oader) and **GRUB** (**G**Rand **U**nified **B**ootloader). When booting, note that no user can achieve administration authorization without a password. This applies both to booting in the single user runlevel and to changing the parameters of the kernel to be booted.

Measure

Prevent the execution of insecure commands by non-authorized persons during the system boot phase.

If the bootmanager is protected with a password it is not necessary to configure a BIOS boot password but a BIOS setup password.

Exception

This measure is not applicable for cloud environments, i.e., on systems without direct console access and without access or implementation of physical ports, BIOS settings, and boot loader settings.

Furthermore, this measure is not applicable on virtualized systems in general.

Implementation

To prevent non-authorized entry of commands during the boot phase, enter a password when using the **LILLO** bootloader in the configuration file `/etc/lilo.conf` via the parameter

```
password=xxxxxxxxx
```

To ensure that the password does not have to be entered for each standard boot process, also enter the parameter

```
restricted
```

in the file `/etc/lilo.conf`.

Protect the file `/etc/lilo.conf`. Owner and group of the file are root. The rights of this file are to be set to 600.

When using **GRUB**, enter the line `password -md5 passwordhash` after the line `timeout` in the configuration file `/boot/grub/menu.lst`. You can create the `passwordhash` within the program **grub** by calling the command **md5crypt**.

When using **GRUB2**, enter the lines `set superusers="root"`
`password_pbkdf2 root passwordhash`
at the start of the configuration file `/boot/grub/grub.cfg`. You can create the `passwordhash` in a regular shell by calling the command **grub-mkpasswd-pbkdf2**.
If particular boot entries are supposed to be protected, add the parameter `-users ""` to each `menuentry` line.

NOTE: Depending on the Linux distribution, this file may be overwritten when updating the kernel. In that case, the setting has to be re-applied after every kernel update.
Protect the files `/etc/grub.conf`, `/boot/grub/menu.lst` and `/boot/grub/grub.cfg`. Owner and group of the files is root. The rights of this file are to be set to 600.

Setting a password prevents unauthorized users making use of other boot options than are provided for in the menu with the bootloader **GRUB**.

With **GRUB**, you cannot only read from storage media, but also boot from other media such as floppy disk or CD-ROM.

The specifying of a boot password can be dispensed with if systems are operated in secure premises.

Solaris x86

Use the command **md5crypt** of the tool `/boot/grub/bin/grub` to generate a password hash:

```
> /boot>/grub/bin/grub
```

```
grub> md5crypt
```

```
Password: *****
```

```
Encrypted: $1$1g5y41$HX2EHzvJIUbBda0m/txBq.
```

```
grub> Control-C
```

Edit `/boot/grub/menu.lst` and add a password line like
`password --md5 $1$1g5y41$HX2EHzvJIUbBda0m/txBq.`

Add the **lock** command to the failsafe entry in `/boot/grub/menu.lst`:

```
title Solaris failsafe
lock
...
```

Red Hat Enterprise Linux

The following steps can be used to protect the boot manager:

1. Use the command **grub2-mkpasswd-pbkdf2** to generate the password hash for a boot password.
2. Create or modify the file `/etc/grub.d/01_users` with the following content

```
cat <<EOF
set superusers="root"
password_pbkdf2 root grub.pbkdf2.sha512.10000.E038...
EOF
```

Replace `grub.pbkdf2.sha512.10000.E038...` with the actual output of the **grub2-mkpasswd-pbkdf2** command.

3. Rebuild the `grub.cfg` file using this command
grub2-mkconfig -o /boot/grub2/grub.cfg
on UEFI-based machines, use this command instead
grub2-mkconfig -o /boot/efi/EFI/redhat/grub.cfg

HP-UX

N/A

AIX

N/A

Revision history:

- 2.2: Minor changes in wording
- 2.3: categorized "mandatory"
- 2.5: Minor changes in wording
- 3.1: BIOS password is not necessary
- 3.2: Add GRUB2 configuration
- 3.3: Added Solaris x86 implementation note
- 3.6: Added exception for virtual systems, added Red Hat Enterprise Linux implementation note

3.1.7 No Biometric Authentication Devices

S,D

mandatory

Measure M950630, modified on 2015-05-31.

Explanation

Some companies offer fingerprint authentication mouse/keyboard devices with capacitive fingerprint sensors. A couple of ways are known to defeat these and other biometric authentication devices. These devices might well be suitable for home application, but the potential risks prohibit using them in a corporate environment.

Measure

Authentication in the Siemens corporate environment must not rely solely on biometric authentication devices. Instead Siemens PKI based smart cards are the preferred mechanism for strong authentication. However, biometric devices that complement the use of smart cards are permitted, e.g., a fingerprint sensor on a smart card (reader) for granting access to the smart card.

Implementation

Do not install / remove any biometric devices that do not complement smart cards.

If PAM is used for authentication, ensure that biometric modules (e.g., pam-fprint, pam-bioapi) are not used.

Revision history:

- 3.0: created measure
- 3.5: Added implementation note.

3.1.8 Disable Firewire (IEEE1394)

D

mandatory

Measure M800954, modified on 2016-04-30.

Explanation

The IEEE1394 specification contains a weakness that allows direct access to a computers main memory (DMA) via a Firewire connection. An attacker can use this method to bypass the authentication mechanisms of locked systems. With other words, access to a machine can be gained without providing any user credentials like smart card, password, etc. It is enough to connect to that machine via Firewire with another computer and run a tool that is freely available on the Internet. Most laptops used within Siemens have a Firewire port built-in.

Measure

Disable all Firewire ports whenever they are not used. Since on most laptops an attacker could simply plug in a PCMCIA (PC card) Firewire adapter, PCMCIA ports must be disabled as well whenever they are not used.

Exception

This measure is not applicable for cloud environments, i.e., on systems without direct console access and without access or implementation of physical ports, BIOS settings, and boot loader settings.

Furthermore, this measure is not applicable on virtualized systems in general. This measure does not apply to systems that are protected against unauthorized physical access.

Implementation

If you do not need any Firewire functionality you must disable Firewire in the BIOS.

Linux

If you do not need DMA support with Firewire you must disable it by loading the Firewire module *ohci1394* with following command **modprobe ohci1394 phys_dma=0**.

HP-UX and Solaris

In HP-UX and Solaris you must disable firewire in the BIOS.

AIX

For AIX Servers you have to unmap all IEEE1394 equipped slots from any LPAR.

Revision history:

- 2.16: measure created and EVAL flag set
- 2.18: removed EVAL flag
- 3.1: categorized and minor wording changes
- 3.2: removed EVAL flag and added AIX specific information
- 3.6: added exception for virtual systems

3.2 Installation and Maintenance

3.2.1 Operating system version

S,D

mandatory

Measure M603120, modified on 2016-04-30.

Explanation

Security leaks and functional problems are regularly found during the life of an operating system, and are usually rectified in the newer version.

Measure

Only use up-to-date operating system versions supported by the manufacturer. According to the *Siemens Circular No. 133* [7], outdated Unix/Linux systems (no vendor support) must not be connected to the corporate intranet.

NOTE: For further details about outdated Unix/Linux systems we refer to the Siemens CERT FAQ about outdated systems https://www.cert.siemens.com/faq/unix/general/allowed_and_outdated_os.

Implementation

Only use up-to-date operating system versions supported by the manufacturer. Otherwise the system has to be either migrated to a newer operating system version, put into a segregated subnet, or taken offline. For further information please see the referenced Siemens circular.

In cloud environments, operating systems supported by the cloud vendor should be preferred.

Right from installation of the operating system you should take care to install only components which are necessary. For example in most cases it is not necessary to install solaris answerbook.

AIX

For AIX, subscribe to the *IBM Lifecycle* notification. While the major AIX release may still be valid, the technology level may be at the end of the lifecycle and IBM will not provide further fixes for this release.

Revision history:

- 3.0: updated CIT Circular
- 3.2: added AIX specific information
- 3.4: updated CIT Circular
- 3.5: references to old Circulars or Corporate Security Policies have been adjusted
- 3.6: added implementation note about cloud environments

3.2.2 Applying security patches

S,D

mandatory

Measure M497003, modified on 2016-04-30.

Explanation

Manufacturers react to deficiencies, which could be, and are, used by attackers by releasing security patches. These correct errors in the programming of portions of the supplied operating system software. The patches are generally incorporated in newer versions of the operating systems, so that fewer patches need to be applied for newer versions.

Measure

Always apply the manufacturer's up-to-date security patches.

The overall system architecture shall support timely patching, e.g., by using planned downtime windows, green-blue deployments, utilizing continuous deployment techniques offered by cloud service providers, etc.

Implementation

The following is a list of the most important manufacturers with addresses for downloading patches:

AIX	http://www.ibm.com/support/fixcentral/
Debian	https://www.debian.org/security
HP-UX	http://itrc.hp.com
Solaris	https://support.oracle.com/epmos/faces/DocumentDisplay?id=1448883.1 , http://www.oracle.com/technetwork/topics/security/alerts-086861.html
Fujitsu	http://patches.ts.fujitsu.com/
SUSE Linux Enterprise	http://support.novell.com/security/
Red Hat Enterprise Linux	https://access.redhat.com/security/updates/advisory/
openSUSE	http://en.opensuse.org/Portal:Security
Ubuntu	http://www.ubuntu.com/usn

Patches should only be applied when they do not conflict with previously installed programs. When in doubt, contact the program's manufacturer. This situation must be documented. In addition, the compatibility of patches should be checked on reference systems.

HP-UX

With the **swlist** command, you can have the current software level displayed on an HP-UX system. Ensure that all security patches are installed by reconciling the software level on the system.

Solaris

Historically, Oracle provided patches for individual versions in so called "Recommended Patches Clusters". This patch clusters are only available for paying Oracle Support

customers. Oracle's supported way for patch updates is now the tool **Solaris Patch Manager**. This tool requires Java to be installed on the system. The command **sm-patch update** will contact Oracle's patch servers, create a list of patches to install, and installs the patches in the correct dependency order. The problem with the tool is that the system needs Internet access which is not always possible and recommended.

Another popular alternative to Oracle's **smpatch** program is the Open Source tool **Patch Check Advanced** available at <http://www.par.univie.ac.at/solaris/pca/>. PCA uses Oracle's `patchdiag.xref` file (<https://getupdates.oracle.com/reports/patchdiag.xref>) which is a list of all available Solaris patches. The tool produces a list of suggested patches and you also have the ability to install them directly.

Red Hat Enterprise Linux

On Red Hat Enterprise Linux you can use the tool **YUM**. The easiest way to update your system is to use the command **yum update**.

SUSE Linux Enterprise

SUSE uses the tool **Yast** to manage the system. You can update the system one with the following commands:

- **yast online_update** (command line interface)
- **yast2 online_update** (graphical user interface)

openSUSE

On openSUSE systems you can use the tool **zypper** with the command **zypper update** to update your system.

Debian, Ubuntu

On Debian and Ubuntu, use the package management system to update the system. All installed packages may be updated with the following command:

apt-get update && apt-get upgrade

AIX

With the **lspp** command you can display the current software level on an AIX system. With the **emgr -l** command you can display the *IBM ifixes* that are fixing certain installed filesets. Ensure that all security patches are installed by reconciling the software level on the system. Furthermore install needed ifixes missing for the installed filesets.

NOTE: It is recommended to not use online update mechanisms which require connection to the vendors update servers located on the Internet. The usage of offline update servers is recommended, e.g., Red Hat Network Satellite.

Revision history:

- 3.0: Minor changes in wording
- 3.1: Updated Links to Solaris
- 3.2: Updated Links and added AIX specific information
- 3.3: Updated Links
- 3.4: Minor change in wording, removed dead link to fujitsu-siemens.com

- 3.5: Added implementation hints for Debian and Ubuntu
- 3.6: Added requirement about overall architecture. Updated links to Solaris information. EVAL flag set.

3.2.3 Siemens CERT Security Telegrams

S,D

mandatory

Measure M653700, modified on 2016-04-30.

Explanation

"Security Telegram" is a service provided by Siemens CERT company-wide and free of charge. Siemens CERT issues a Security Telegram if there is a known vulnerability of one of the supported operating systems or applications, and if a patch or workaround is available to fix this vulnerability. A Security Telegram typically contains a telegram style description of the vulnerability, affected platforms, links to Intranet-copies of security patches and links to further information.

The normal way to use the Security Telegram service is to subscribe to an E-Mail distribution list. For more information please refer to <https://www.cert.siemens.com/sectel/subscribe>.

In addition, a list of all security telegrams that have been released is available on the Siemens CERT web server <https://www.cert.siemens.com/sectel/> as well as on the Siemens CERT ftp server ftp://ftp.cert.siemens.com/pub/Security_Information/SecurityTelegram/.

Measure

Apply the measures from Siemens CERT Security Telegrams relevant to your specific system configuration in a timely fashion. The list below shows the maximum time frame for applying measures depending on the priority of the Security Telegram after its publication.

- Priority 1: 7 working days
- Priority 2: 20 working days
- Priority 3: 20 working days

The overall system architecture shall support timely patching, e.g., by using planned downtime windows, green-blue deployments, utilizing continuous deployment techniques offered by cloud service providers, etc.

NOTE:

- A Security Telegram may allow a maximum implementation time frame different to the regular time frame (as described above) in exceptional cases (e.g., a Service Pack). In such a case, the exceptional time frame is clearly stated in the Security Telegram.
- However, as critical business applications may depend on components which are affected by the provided Security Patch, appropriate testing before implementing a Security Telegram is strongly recommended. If any negative impact on the core functionality of your IT-systems resulting from a Security Telegram is detected, implementation must be authorized by your superior and, if necessary, agreed with your local InfoSec responsible.
- This measure also applies to systems operated in virtualized or cloud environments.

Implementation

Subscribe to the Security Telegrams, test and implement Security Telegrams according to this measure.

Revision history:

- 3.0: created measure
- 3.5: added implementation section
- 3.6: Added requirement about overall architecture. EVAL flag set.

3.2.4 Install Corporate Scan Service Software Agent

S,D EVAL

mandatory

Measure M447301, created on 2016-11-30. **EVAL** flag expires 2017-06-30.

Explanation

The *Vulnerability Scanning* team (GS IT ISEC) provides the *Corporate Scan Service* to analyze Siemens IT systems connected to Intranet or to the Internet looking for known vulnerabilities. To that end, the *Corporate Scan Service* uses a software agent on each IT systems to provide better and more accurate results than a normal network scan.

After installation, the software agent connects to the central scanning application, scans periodically the server for known vulnerabilities, and reports back the scan results.

Measure

Install the *Corporate Scan Service* software agent on server systems if the server is connected to the Siemens Intranet.

Note: To address found vulnerabilities, the IT system must be registered correctly in the respective corporate repositories and the data must be kept up-to-date (see [Section 2.5](#), Documentation of the IT landscape).

Implementation

For installation and maintenance, follow the installation instructions provided on following intranet web page: <https://ipinsplus.siemens.com/qAgent>.

On this web page you will also find additional information whom to contact in regard to questions about the software agent.

Revision history:

- 3.7: Measure created.
This change was submitted after the review phase: EVAL period prolonged to 2017-06-30.

3.3 Local Security

3.3.1 Enable Stack Protection

S,D

mandatory

Measure M505607, modified on 2015-05-31.

Explanation

The most common vulnerabilities on Unix and Linux systems are Stack based Buffer Overflows which can be exploited remotely or locally. The problem with this vulnerability is that it is not easily fixable. Nevertheless some vendors developed techniques (e.g., NX-Bit) to protect the system from this kind of attack.

Measure

If your hardware and operating system distribution support one of these techniques, you must enable it.

Implementation

Solaris

On Solaris you can enable the stack protection by setting following values in the file `/etc/system`:

```
set noexec_user_stack = 1
set noexec_user_stack_log = 1
```

Linux

Recent Linux kernels (2.6.8 and later) turn on stack protection by default, if the underlying hardware architecture (e.g., x86 64 bit and 32 bit) supports it.

The Kernel parameter `kernel.randomize_va_space` must be set to 1 or higher.

You may check the current setting with `sysctl kernel.randomize_va_space` or with `cat /proc/sys/kernel/randomize_va_space` on most Linux distributions.

AIX

On AIX you have to use the Stack Execution Disable (`sedmgr`) to ensure stack based protection. You can configure this with the **sedmgr** command.

Revision history:

- 3.0: Created the Measure
- 3.1: Removed EVAL Flag
- 3.2: Added AIX specific information and added clarification for Linux
- 3.4: Allow conservative(1) and full(2) address randomization in Linux implementation note.
- 3.5: Allow values larger than 2 for particular hardened Linux kernels. Added note on how to check current setting.

3.3.2 Enable link protection

S,D

mandatory

Measure M447734, created on 2015-05-31.

Explanation

The hard link and symbolic link mechanism can be used by attackers to redirect the file operations of a victim's process to a destination defined by the attacker.

The Linux kernel offers a protection mechanism for some of the attack scenarios:

hardlink protection restricts users from creating hard links to files they do not own, or do not have read/write access to it.

symlink protection allows following of symbolic links only when outside a sticky world-writable directory, or when the uid of the symlink and follow match, or when the directory owner matches the symlink's owner.

Measure

If supported by the Linux kernel, *protected symlinks* and *protected hardlinks* must be enabled.

Implementation

NOTE: The support for this protection mechanism starts with Linux kernel version 3.6.

The following Kernel parameters must be set to 1:

- *fs.protected_symlinks*
- *fs.protected_hardlinks*

NOTE: Most Linux distributions have this setting enabled by default.

To check the settings, the following commands can be used:

- **sysctl fs.protected_symlinks**
- **sysctl fs.protected_hardlinks**

Revision history:

- 3.5: Measure created

3.3.3 Disable Core Dumps

S,D

mandatory

Measure M604007, modified on 2015-05-31.

Explanation

A core dump is a file which consists of the recorded state of working memory of a program or the kernel. On most UNIX and Linux systems core dumps will be created when the kernel or an application crashed for later analysis of the problem.

These files may include confidential data, i.e., passwords and other credentials. An attacker, who may get access to the files, can use this information to get access to the system. Therefore, core dumps must be protected or disabled.

Measure

Disable the creation of core dumps if this feature is not needed. Otherwise restrict the access to the file by setting appropriate file access rights.

Implementation

AIX

If you need the core dump feature on AIX, change the default dump directory to a separate directory with 700 permissions, as the system default `/var/adm/ras` is a 1777 directory.

Solaris

Since Solaris 7 Oracle is providing the tool **coreadm** to control the core behavior in the kernel. Solaris can dump a global core file and a per-process core file. Use the command

coreadm -d global -d global-setid -d process -d proc-setid

to completely disable the creation of coredumps. If you need core dumps you have to protect them. On Solaris, the kernel writes core dumps as root and thus you can tell **coreadm** to write all core files to a directory that is only readable by root:

```
coreadm -g /var/core/core_%n_%f_%u_%g_%t_%p \  
-e log -e global -e global-setid \  
-d process -d proc-setid
```

with %n the system hostname, %f the process name, %u the user owner, %g the group owner, %t the timestamp, and %p the PID.

Linux

On Linux you can deactivate the creation of core dumps for interactive user logins by editing the file `/etc/security/limits.conf` and add the line:

```
* hard core 0
```

The problem with `/etc/security/limits.conf` is that it only controls settings for

user logins but not for processes started at boot time. Furthermore, this limit is ignored by the Linux kernel, if it is configured to forward core dumps to a crash-handling application instead of writing it to a file.

Globally disabling all core dumps for all processes on a system can be achieved

- if **systemd** is used on the system to handle core dumps by setting the corresponding storage type to *None*.
This can be achieved by creating the file `/etc/systemd/coredump.conf` with the following content:
Storage=none
- by setting the name of core files to `/dev/null`. This can be achieved by setting the following kernel variables:
 - *kernel.core_pattern = /dev/null*
 - *kernel.core_uses_pid = 0*

NOTE: To avoid automatic overrides of these settings, software that generates crash reports by registering itself as recipient of core dumps should be disabled. Therefore, on Ubuntu Linux, the tool **apport** should be uninstalled.

AIX

On AIX you can disable the core dump creation for user programs by editing the file `/etc/security/limits`. Modify the default section by adding the following lines:

```
core = 0
core_hard = 0
```

Check all other section (users) for settings that will overwrite the default ones. Check `/etc/profile` for different **ulimit** settings that will overwrite the system defaults.

Disable the advanced dump of AIX by disabling the fullcore feature.

chdev -l sys0 -a fullcore=false

Set system dump null devices as primary and secondary devices for disabling of the dump for the kernel.

```
sysdumpdev -Pp /dev/sysdumpnull
sysdumpdev -Ps /dev/sysdumpnull
```

Revision history:

- 3.0: Created the Measure
- 3.1: Categorized as mandatory
- 3.2: Removed EVAL Flag
- 3.5: Added hint on how to globally disable core dumps on Linux kernel level, measure becomes mandatory for all system types, EVAL flag set

3.3.4 Protect Single User Mode with Password

S,D

mandatory

Measure M200587, modified on 2016-04-30.

Explanation

When booting into single user mode some UNIX and Linux distributions do not prompt for a password and so the user booting the system has full root access.

Measure

When a system is started in single user mode, the system must prompt for root password by default.

Exception

This measure is not applicable for cloud environments, i.e., on systems without direct console access and without access or implementation of physical ports, BIOS settings, and boot loader settings.

NOTE: The measure must be applied on virtual environments allowing direct console access, e.g., systems hosted on VMware ESXi or VMware Workstation.

This measure does not need to be implemented on systems which have all of the following measures implemented:

- Measure 3.1.2 (M680620)
- Measure 3.1.3 (M201280)
- Measure 3.1.6 (M112800)

Implementation

Edit the file `/etc/inittab` and add the line:

```
sum:S:wait:/sbin/sulogin
```

Solaris

Solaris Systems do prompt for a password and so no action is required.

AIX

AIX has password protected single user mode by default/design.

Revision history:

- 3.0: Created new Measure
- 3.1: Removed the EVAL flag
- 3.2: Added AIX specific information
- 3.4: Added exception for combination of alternative measures
- 3.6: Added exception for cloud environments

3.3.5 Setting Umask

S,D

mandatory

Measure M730750, modified on 2015-05-31.

Explanation

For many UNIX systems the default for **umask** is *000*, which means that everyone has write access for newly created files. The explicit assignment of the **umask** prevents the unauthorized generation of files by the user without corresponding access rights.

Measure

Set the **umask** value to either *077* or *022*. The more restrictive setting of *077* is preferred.

Implementation

Check to ensure that the system's default **umask** is at least *022*. Enter the corresponding value in the relevant startup and profile files, e.g., */etc/profile*, */etc/cshrc*, */etc/default/login*, or */etc/login.defs*.

Solaris

Starting with Solaris 8, the default **umask** for all process started by **init** is set to the value of *CMASK* from the file */etc/default/init*. The default value is *022*. If possible, change this value to *077*.

HP-UX

If the graphical interface **CDE** (Common Desktop Environment) is used, you can set **umask** as follows for all users:

- Create a new file in the directory */etc/dt/config/Xsessions.d*
- Enter the following information in this file: *umask 077* (or *umask 77*)
- Set the access rights: **chmod 755 /etc/dt/config/Xsessions.d/filename**

Red Hat Enterprise Linux

On Red Hat systems you must set the **umask** value in the file */etc/rc.d/init.d/functions* to the value *077*. This will set the correct **umask** value because every boot script begins by calling the file */etc/rc.d/init.d/functions* and so the **umask** value will be automatically inherited.

SUSE Linux Enterprise, Ubuntu, Debian

Edit the file */etc/login.defs* and modify the **umask** settings for the default user. Consequently, it is required to use the PAM module *pam_umask*. Furthermore check every other user for **umask** values that differ from the required setting in this file.

AIX

Edit the file */etc/security/users* and modify the **umask** settings for the default user. Furthermore check every other user for **umask** values that differ from the required setting in this file.

Revision history:

- 2.2: Added profile files. Minor changes in wording.
- 2.3: categorized "mandatory"
- 2.19: changed URL
- 3.0: Updated Implementation section
- 3.2: clarification: either mode 022 or 077 and added AIX/SLES specific information
- 3.5: included Ubuntu, Debian in implementation section

3.3.6 Scheduled service security

S,D EVAL

mandatory

Measure M608700, modified on 2016-11-30. **EVAL** flag expires 2017-02-28.

Explanation

Services like **cron** or **systemd** allow security-critical procedures to be started. Insufficient permissions of configuration files of such applications allow attackers to start malicious procedures.

Measure

Check the access rights for all files triggering such scheduled services, whenever they are related to your operating system. Make sure to do the same for all procedures which are called up through them.
 Limit the use of such scheduled services to trustworthy users as far as your system offers this restriction.

Implementation

The following items must be considered:

- Check that all configuration files triggering scheduled services entries have legitimate purposes.
- Only allow trustworthy users to create and modify scheduled services.
- Check all files which are used to trigger automated tasks and the initiated procedures for their access rights, particularly write permissions.
- Ensure that all configuration files triggering scheduled service entries carried out by root can only be modified by the root user.

Linux (systemd-based)

Unit files can be used as an alternative to the traditional **cron** daemon. To find such services taking advantage of the *Timer* functionality, the following command can be used:

```
find / -type f \( -name "*.timer" -or -name "*.service" \) -exec grep -li "Timer" {} \;
```

Systems using dedicated cron-daemons

The following rules must be applied to the system crontab (e.g., /etc/cron.d/*) files:

- Every crontab file must only be writable by root.
- For these files, the owner and the group must be root.

For user crontab files the write permission must not be granted except for the owner. Only add trustworthy users to the `cron.allow` file.

AIX

You must create the `/var/adm/cron/cron.allow` file, as this is not in place by default.

```
echo "root" > /var/adm/cron/cron.allow  
chown bin:cron /var/adm/cron/cron.allow  
chmod og-w /var/adm/cron/cron.allow
```

Revision history:

- 2.1: changed "For Linux and BSD" to "For BSD"
- 2.2: Minor changes in wording
- 2.3: categorized "mandatory"
- 3.0: updated the implementation section
- 3.1: updated the implementation section
- 3.2: clarification: root crontabs != system crontabs, removed EVAL flag and added AIX specific information
- 3.7: Added systemd implementation details. Renamed title to cover all scheduled services.
This change was submitted after the review phase: Precised *Measure* section.

3.3.7 Protecting System Files

S,D EVAL

mandatory

Measure M802906, modified on 2016-11-30. **EVAL** flag expires 2017-02-28.

Explanation

The exchange of system files may, for example, allow the installation of Trojan horses on the target system. The assignment of appropriate access rights helps to prevent the modification/overwriting of these files with the use of unauthorized IDs.

Measure

Important system files should be protected against copying or manipulation.

Implementation

Files used to trigger services at startup must belong to root, and no-one apart from root is allowed to have write rights. This also applies to other files that should be executed by root and the containing directory trees. Normally, no one requires write rights under /etc or /usr/local/etc apart from root, and all files can belong to root. Examine this for your system and change privileges following consultation.

Linux (SysV-based)

Check the rights for startup scripts /etc/rc*, /etc/rc?.d/*, /usr/local/etc/rc.d/*, and /etc/init.d/*.

Linux (systemd-based)

Check the rights for all unit files via `find / -mount -type f -name '*.unit' -or -name '*.service'` and correct them if necessary. Be aware that the execution of this command may produce heavy load on systems containing a huge amount of files and directories. On such systems, restrict the command to standard systemd folders like /usr/lib/systemd/ and /etc/systemd/user/. Those folders are distribution-dependent and may vary on your system. The same issue applies to the file extension of systemd configuration files as .unit and .service are the two most common extensions used on most Linux distributions.

Solaris

Since Solaris 10 default permissions are secure.

SUSE Linux Enterprise

Under SUSE Linux, system files can be checked for their parameter setting and corrected using the program **chkstat** and the reference files /etc/permissions.*.

AIX

For AIX, functional users and groups can have write rights on files residing in /etc. This is especially true for the users **bin ipsec** and **groups printq security system bin adm**.

Revision history:

- 3.0: updated Implementation section
- 3.2: update broken link and added AIX specific information

- 3.4: updated link to JASS
- 3.5: removed implementation note for outdated Solaris versions
- 3.7: Added systemd implementation details

3.3.8 Home folders

S,D EVAL

mandatory

Measure M406350, modified on 2016-11-30. **EVAL** flag expires 2017-02-28.

Explanation

Users can compromise the security of the entire system through unmonitored activity. Regular monitoring is a necessary component of secure system administration.

Measure

Regularly monitor the access rights to all home folders on your system. This check should contain the following items for all users:

- Check that every home folder is owned by the assigned user or the root user, and its access rights are set to 755 or more restrictive.
- Check that every `.netrc` file present is owned by the assigned user, and its access rights are set to 600. These files may contain data for logging on to a distant computer for data transfer via **ftp** (e.g., passwords).
- Check that every `.telnetrc` files present is owned by the assigned user, and its access rights are set to 600.
- Check that the directory `.ssh` is owned by the assigned user and its access rights are set to 700. The files in this directory contain keying material.
- Check that every file in a home directory that is executed during logon, e.g. `.bashrc` or `.profile`, and every file that contains configuration data for applications has its access rights set to 755 or more restrictive.
NOTE: This check may be non-recursive.

Additionally, for the root user, the following checks are mandatory:

- The home folder of the root user must reside on the root partition (i.e. the partition mounted to mountpoint `/`). The reason is given in the Filesystem Hierarchy Standard (<http://www.pathname.com/fhs/>): If the home directory of the root account is not stored on the root partition it will be necessary to make certain it will default to `/` if it cannot be located.
- If root's home directory is not `/`, its access rights must be set to 750 or more restrictive. Otherwise, the access rights of all directories and files belonging to the user root (and not the system) must be set to 700 or more restrictive.

Non-interactive users (e.g., `bin`, `sys`):

- Prohibit login, e.g., by setting the login shell to `/bin/false` or `/sbin/nologin`.

Implementation

The list of home directories may be retrieved from the sixth field of `/etc/passwd`. This can serve as basis for the implementation of the required, regular checks.

In some Unix operating systems (Solaris, HP-UX), the home folder of the root user is / by default. In this case it is recommended to move root's home folder to a separate directory, e.g., /root. This way, system files and files of user root become more distinguishable and the listing of root's home directory can be prevented.

NOTE: Users who cannot access their home folder at login time may be redirected to / automatically. Some operating systems support the configuration to deny logins for users with missing home directories (e.g., HP-UX 11.11, 11.23: set `ABORT_LOGIN_ON_MISSING_HOMEDIR=1` in `/etc/default/security`) – this is recommended.

Revision history:

- 3.0: Updated the implementation section
- 3.1: Changes in implementation section
- 3.2: Removed EVAL flag
- 3.3: Check of "dot files" in home directories
- 3.5: Moved mandatory parts from the implementation section to the measure section, EVAL flag set
- 3.7: Changed root home folder rights from 700 to 750, EVAL flag set

3.3.9 Links in the folder /tmp

S,D

mandatory

Measure M805036, modified on 2016-11-30.

Explanation

The folder /tmp is readable and writeable for all users. Any user can create files in this folder. It is therefore possible for a user to create links in this folder with any name, pointing to system files. If applications with administrative rights in the folder /tmp write in temporary files and the file names are known or easy to guess, then an application can overwrite system files via such a link. The modification of system files can generate enormous system problems.

Measure

Check the folder /tmp regularly for links and files with administration rights.

Exception

This measure can be ignored on systems implementing Measure 3.3.2 (M447734).

Implementation

Check for the existence of links in the folder /tmp that link to files outside of /tmp. If possible delete all links in this folder. To find the links, you can use the command **find /tmp -type l -and -lname '/' -or -lname '*..*'**.

Revision history:

- 2.3: Categorized "mandatory"
- 3.2: Add exception for internal links
- 3.7: Added exception as measure is actually part of Measure 3.3.2 (M447734) on systems running on recent kernel versions, no need to set EVAL

3.3.10 Existing user and group for all files

S,D EVAL

mandatory

Measure M509730, modified on 2016-11-30. **EVAL** flag expires 2017-02-28.

Explanation

File ownership can be set to user IDs and group IDs not known to the system. Consequently, these files cannot be easily assigned to an application or user which may pose a security risk.

Measure

Regularly monitor the file ownership on local media to reveal files owned by non-existing users and groups.

Exception

This measure does not apply to paths containing a shared file system. Such paths typically host files from other systems with different user bases. Examples for suchlike systems are NFS servers and Virtuozzo hosts.

Also, this measure does not apply to paths where subsystems using their own user base are residing. A typical example for such a subsystem is a chroot jail environment.

Implementation

- Check the system in intervals no longer than 90 days for files with unknown user or group IDs. This can be achieved with a command like **find / -nouser -o -nogroup**
- Avoid unpacking archives with root permissions as this allows the unpacking application to create files with arbitrary user and group IDs.
- After removing a user account or group, check the system for files owned by the removed account.

Revision history:

- 3.3: Measure created
- 3.4: Exception defined for hosts with shared file systems, prolonged EVAL period
- 3.7: Added exception for chroot jails. Rewrite of exception for hosts with shared file systems. Switched to path-based exceptions instead of host-wide ones.

3.3.11 Monitoring SUID and SGID files

S,D

mandatory

Measure M812040, modified on 2012-05-31.

Explanation

Unmonitored SUID and SGID programs often represent a back door for attackers.

Measure

Regularly monitor all SUID and SGID files on your system.

Implementation

Create a list of all SUID and SGID files and regularly check the results against a reference list. This must be performed at least once a month.

To perform a search for files with an s-Bit, use the following command:

```
find / -type f \( -perm -2000 -o -perm -4000 \) -print
```

To search for shell procedures with an s-Bit use the following command lines:

```
find / -type f \( -perm -2000 -o -perm -4000 \) -exec file {} \; | grep -v "executable"
```

The output must be diverted into a file, which can only be read via the root ID. This file will then be used as a reference file.

If one of the found files does not require a setuid or setgid bit as discussed below, then you must remove these bits with the command:

```
chmod -a <file>
```

AIX

AIX has a tool for verifying if important sBit files have been modified. The status of the files can be queried with the following command:

```
fpm -l default -c -v
```

Revision history:

- 2.2: Minor changes in wording
- 2.3: categorized "mandatory"
- 2.5: Minor changes in wording
- 3.0: Updated the Implementation section
- 3.2: Added AIX specific information

3.3.12 Disable Automount and Autorun

S,D EVAL

mandatory

Measure M809740, modified on 2016-11-30. **EVAL** flag expires 2017-02-28.

Explanation

Modern UNIX and Linux distributions include a feature to automatically mount a removable device. This feature works without superuser (root) rights. Further, these distributions allow to autorun a specific application on the media. If the removable media contains executables with the setUID bit set, this situation poses a significant threat to the system: autorun in combination with automount would allow an attacker or unsuspecting user to mount a media without administrative rights, but autorun an attacker-created executable with setUID bit set, thus running arbitrary code on the system with administrative rights. This allows to, e.g., install setUID copy of a shell, compromising the system.

Measure

Disable the automatically mounting for all removable devices. You must also disable the autorun feature when supported.

Implementation

Linux (systemd-based)

Check all automount unit files on your system via **find / -type f -name '*.automount'**. In case those files cover removable devices, delete the files or disable them by using **systemctl**.

Linux (SysV-based)

Disable the **autofs** service or configure it to not mount removable media.

Solaris

For Solaris you can disable the "volume manager" with the command **svcadm disable volfs**.

AIX

In AIX the tool **cdmount** is used to automount external devices. To deactivate automounting you must disable the **cdmount** utility. More details on how to deactivate the service can be found in **fileset bos.cdmount**.

Revision history:

- 3.0: Created the measure
- 3.1: Removed the EVAL flag
- 3.2: Added AIX-specific information
- 3.5: Change in Red Hat implementation note, removed Solaris implementation notes for outdated versions
- 3.7: Added systemd implementation details

3.3.13 Preventing shutdown without login

D

mandatory

Measure M700784, modified on 2016-04-30.

Explanation

Some manufacturers deliver their systems with IDs (shutdown, stop, etc.) that allow the system to be shut down without prior authorization.

Using the console, the operating system Solaris offers the possibility of switching the OS into monitor mode, also known as **OBP** (open boot prompt) mode. In this mode you can boot the system.

Measure

Opportunities for shutting down a system without authorization must be prevented.
NOTE: Shutdown actions initiated by the hypervisor, cloud console, or cloud API do not require authentication or authorization from the client OS.

Implementation

Check to ensure that no such mechanisms are in place on your systems.

Red Hat Enterprise Linux 7

For Red Hat Enterprise Linux 7 and other systems managed by **systemd**, the following command disables system shutdown with **<Ctrl>-<Alt>-**:

```
systemctl mask ctrl-alt-del.target
```

Linux (non-systemd)

Under Linux, system shutdown with **<Ctrl>-<Alt>-** must be prohibited in the file `/etc/inittab`.

Solaris

If a console of a Solaris system is not in a secured room you have to prevent the use of **<Stop>+a**.

Running **kbd -a disable** at a shell prompt will disable keyboard interrupts. After running this command, neither **<Stop>+a** nor disconnecting the keyboard will switch the system to the monitor mode.

Since this behavior only lasts until the next reboot, you must additionally add the following line to the file `/etc/default/kdb`: `KEYBOARD_ABORT=disable`. This way keyboard interrupts are disabled permanently.

AIX

N/A

Revision history:

- 2.1: Added "Solaris" heading; clarified temporary and permanent solutions for Solaris
- 2.2: Minor changes in wording
- 2.3: categorized "mandatory"
- 2.16: minor changes in format and wording
- 3.6: Measure does not affect actions initiated by the virtualization layer. Added implementation note for Red Hat Enterprise Linux 7.

3.3.14 Secure Configuration Files

S,D EVAL

mandatory

Measure M447647, created on 2016-11-30. **EVAL** flag expires 2017-02-28.

Explanation

Configuration files are read by services in order to ensure proper functionality and security of the running service. Changes to those files can lead to services skipping security features. Thus, unintended changes to those files may lead to information leakage or denial of service attacks. Most services do not need to change their configuration files on their own. Due to this, denying write-access to those files for users running the actual service, can ensure that no unintended changes take place.

The responsibility to implement this measure lies with the owners of the service.

Measure

Prevent unauthorized modifications of service configuration files through corresponding service processes.

Exception

This measure can be skipped for selected services whenever the particular service requires write-access to configuration files for proper functionality.

Implementation

Typically, such configuration files reside under /etc. To change rights of configuration files to read-only, a command like `chmod 400 /etc/service/file.config` may be used.

Revision history:

- 3.7: Created new Measure

3.4 Malware Protection

3.4.1 Standard Virus Scanner	S,D	EVAL
		mandatory

Measure M250305, modified on 2016-11-30. **EVAL** flag expires 2017-02-28.

Explanation

Viruses, Ransomware and backdoors are big problems in today's network environments. Every day numerous new viruses become known and attack users via email or files downloaded from the internet.

Although most of this malware attack Windows based systems, all networked systems can be used for distribution via common protocols and interfaces (mail, file shares, upload/download areas on FTP/HTTP servers). Moreover, there are platform independent backdoors which target systems at application level like malicious php scripts or Java applications.

Measure

On every system

- a Virus Competence Center (VCC) compliant virus scanner engine must be installed.
- before execution, the integrity of any executable file triggering the initial virus scanner engine installation, must be verified by using hash sums as published by the VCC.
- the virus signatures must be updated at least twice a day by using VCC resources.
- the virus scanner engine must be kept up-to-date.
- at least the following files must be scanned via on-access scanning or frequently recurring scans:
 - exported file systems like files exported via Samba
 - stored e-mail
 - directories containing dynamic or static web content like html files, jsp files, and files offered as download
 - directories where users can upload content.

Exception

Standalone systems and hosts suffering from performance or availability issues with virus scan engines offered by VCC must at least implement Measure **3.4.2** (M447203).

Implementation

It is recommended to have clearly defined responsibilities between OS operations and application owner about virus scanning.

Installation

The Virus Competence Center (VCC) offers a virus scan engine for various Linux flavors. Please visit <https://virusprotection.it-solutions.atos.net/download/unix> for installation guidelines. Make sure to check the hash sum stated by the VCC website before installation of the downloaded file. Usually, this can be achieved by comparing the result of the following command with the hash sum stated by VCC:

```
sha256sum /tmp/agent.*
```

Update

All regular installed VCC virus scan engines are updated in a central way. This fact holds true for virus signatures as well as the actual virus scan engines. No manual task is required as all updates are triggered by VCC. For further information please refer to the VCC website at <https://vcc.siemens.com>.

Revision history:

- 3.2: add note about VCC sideline
- 3.3: minor change in wording
- 3.4: mandatory installation of virus scanner, EVAL flag with extended time period set
- 3.5: Added scanning of web content and upload directories, recommended scan interval, EVAL flag set
- 3.6: Prolonged EVAL period
- 3.7: minor title change. Complete rewrite in cooperation with the Virus Competence Center

3.4.2 Special Virus Scanner

S,D EVAL

mandatory

Measure M447203, created on 2016-11-30. **EVAL** flag expires 2017-02-28.

Explanation

Some systems are not able to take part in the standard virus scan engine process of Virus Competence Center (VCC). Those hosts may not be connected to any VCC server for specific reasons. Only these systems are in focus of this measure.

Measure

Only systems meeting at least one of the following requirements are allowed to implement this measure instead of Measure 3.4.1 (M250305):

- systems not able to take part in the central VCC update process because of technical or organizational reasons
- Linux/Unix-based platforms for which no VCC solution is offered. Please refer to <https://virusprotection.it-solutions.atos.net/download/unix> for a list of all VCC supported platforms
- hosts where the implementation of Measure 3.4.1 (M250305) leads to significant availability, security or confidentiality problems.

On every system a current and vendor supported anti virus solution must be installed and configured to address the following issues:

- the virus signatures must be updated at least twice a day.
- the virus scanner engine must be kept up-to-date.
- at least the following files must be scanned via on-access scanning or frequently recurring scans:
 - exported file systems like files exported via Samba
 - stored e-mail
 - directories containing dynamic or static web content like html files, jsp files, and files offered as download
 - directories where users can upload content.

Exception

Systems implementing Measure 3.4.1 (M250305) do not need to implement this measure.

Implementation

The implementation is highly depended on the anti virus solution, so no general implementation details can be given.

Revision history:

- 3.7: Measure created
This change was submitted after the review phase: Rewrote *Measure* and *Exception* part to precise measure.

3.5 Network Security

3.5.1 Check active Network Connections

S,D

mandatory

Measure M202900, revised on 2016-11-30.

Explanation

For potential attackers, various port scanning systems offer the means of finding all open network connections on a system. It is therefore important to know and control all open network connections for every system. A regular check of these connections also enables you to reveal Trojans and unknowingly initiated insecure network connections.

Measure

Check all programs which are listening on public network interfaces if this service is mandatory for the system.

Implementation

With the **netstat** program you can check all the network connections on a system. The **-p** switch also displays the related processes for each network connection.

The **netstat** program can provide the results of a portscan from the system side and show the processes which started the connections.

The **netstat** program also displays all existing connections to other systems. Start the **netstat** program with the following switches:

- **-t** for TCP connections
- **-u** for UDP connections
- **-w** for raw devices
- **-a** for all connections (LISTEN and ESTABLISHED)
- **-p** for processes

The command **netstat -tpwau** displays all the existing and open network connections on a system.

On Solaris systems, the command **netstat -a -f inet -v -n** displays all existing and open IPv4 network connections. With the command **netstat -a -f inet -f inet6 -v -n** you can also list all IPv6 network connections.

Save the results of this search in a file and check your system regularly (at intervals of no more than 90 days) for new and unusual network connections.

AIX

On AIX systems, the command **netstat -a -f inet -n** displays all existing and open IPv4

network connections. With the command **netstat -a -f inet -f inet6 -n** you can also list all IPv6 network connections.

Revision history:

- 2.3: categorized “mandatory”
- 2.20: corrected the netstat command for Solaris
- 3.2: Added AIX specific information
- 3.7: Fixed typo in measure section, no need to set EVAL.

3.5.2 Disable Unneeded Network Protocols

S,D

mandatory

Measure M307609, revised on 2016-11-30.

Explanation

A UNIX or Linux operating system comes with a lot of network protocols installed by default. There are some known problems in the design or the implementation of these network protocols.

Measure

Disable unneeded protocols, e.g., Sctp.

Implementation

The Stream Control Transmission Protocol (SCTP) is supported by most of today's operating systems even there are still only a few applications which are using it. New protocol implementations are often subject to various vulnerabilities. Therefore protocols which are not used by applications must be disabled.

For example, to disable Sctp in Linux you must stop loading the `sctp.ko` driver.

NOTE: This is only an example how to disable the Sctp protocol. Other protocols may be disabled in another way.

NOTE: Due to a defect in Solaris 10, the system would be unbootable, if Sctp was disabled. Therefore, Sctp must not be disabled on Solaris 10. This defect has been corrected in Solaris 11 FCS and above.

Revision history:

- 3.0: Created new Measure
- 3.1: Removed the EVAL flag and added implementation section.
- 3.2: Added another example
- 3.3: Note about Sctp on Solaris 10
- 3.4: Minor change in wording
- 3.7: Fixed typo in measure section, no need to set EVAL.

3.5.3 Securing Bluetooth

S,D

mandatory

Measure M740601, revised on 2015-05-31.

Explanation

Bluetooth provides the functionality to pair two devices remotely. It is important that Bluetooth is configured in a secure way to prevent remote attacks.

Measure

To ensure that systems cannot be attacked via Bluetooth, the following measures must be considered:

- The Bluetooth device must be non-discoverable.
- The Bluetooth security features, like authentication and encryption, have to be implemented on the Link Layer.
- The Bluetooth device has to be configured such that a remote device is not able to get the Bluetooth device class.
- Bluetooth Personal Area Networking (PAN) is not allowed and all related services have to be disabled.
- Only necessary Bluetooth Information Exchange Services (BIE) should be enabled. All other services have to be disabled.
- The Bluetooth COM Port services are allowed to be used for serial communication, for modem connection, and for synchronization purposes.
- The use of headsets and the Bluetooth Handsfree Profile are allowed.
- For file transfer over Bluetooth you must set a secure password.
- The user must be informed interactively by a dialogue (or similar) when data is to be received.
- It is not allowed to select a default application that will automatically handle a received file, e.g., v-card.

Implementation

Implement topics according to the measure rules.

Revision history:

- 2.16: removed EVAL flag
- 3.5: added note in the Implementation section

3.6 Account and Access Control

3.6.1 Concept of Least Privileges for Users

S,D

mandatory

Measure M910080, modified on 2016-04-30.

Explanation

Users should have only as much rights as absolutely necessary in a domain and on their workstations. Moreover, users should just be "Users", in their computer environment, i.e. member of the group "users".

Administrative users should be allowed to perform their administrative task, but not given the unlimited rights of the root user.

Measure

Apply the concept of least privileges to all users and admins.

- Per default one may only work with higher than standard user privileges for the duration of operations those require administrative privileges.
- Avoid configurations allowing users to gain higher than standard privileges without authentication, e.g., the NOPASSWD option should not be used in `/etc/sudoers`.
NOTE: This applies only to user accounts. Accounts used for automatic, remote system maintenance must be restricted in the commands which are allowed to run with elevated privileges.
- Cloud providers use the NOPASSWD option for the standard user to allow execution of privileged commands without additional authentication (e.g., **ec2-user** in Amazon Web Services). Suchlike accounts must be
 - disabled, e.g., by disabling the SSH service, OR
 - treated and secured like the root account.

Implementation

One way to achieve this goal is the usage of **sudo** which allows users to run programs with the security privileges of another user (usually the root user).

sudo requires the calling user to enter his password. This is an important distinction, because it means you can delegate administrative responsibility to users without having to supply everyone with the root password.

sudo is configured in the `/etc/sudoers` file. One should use the **visudo** tool to edit the file, as it will check the configuration for correctness. The manual page for **sudo** and **sudoers** should be consulted before the implementation.

A whitelist approach should be chosen to implement the concept of least privileges, i.e. assemble a list of users and/or user groups with the corresponding commands they

need to execute. Be as restrictive as possible.

The basic format of the user specification in the `/etc/sudoers` file looks like:

user hostlist = (userlist) commandlist

where

- user is the name of the user or group to which this rule applies
- hostlist is a list of hosts this rule applies to
- userlist is a list of users that this rule can be run as. It is optional and must be enclosed in brackets
- commandlist is a list of commands that this rule states can be executed

Example: To allow users of the group wheel to run a particular command one can use:

```
%wheel ALL = /usr/bin/pon, /usr/bin/poff
```

This lets all users in the Unix group wheel run the commands `/usr/bin/pon` and `/usr/bin/poff`.

Generic configuration rules:

- Avoid usage of the NOPASSWD option, as it allows execution of commands without entering a password.
- Limit the password caching to the needed minimum duration or disable it completely (the default is 5 minutes).
- Avoid usage of wildcards in the `/etc/sudoers` file as they can confuse your concept of privilege limitation.
- Do not use the token ALL for the commandlist field in the `/etc/sudoers` file.
- Provide complete paths for commands, as if you merely include the executable name, a user could gain root access through malicious code execution.
- Check the rights for scripts called by sudo. The files must belong to root, and no-one apart from root is allowed to have write rights. This also applies to other files that should be executed by root and the containing directory trees.
- Do not allow sudo for well-known applications which allow to escape to the shell (e.g., **vi**, **vim**, **emacs**, etc.) or use it in combination with the parameter *NOEXEC*
- Do not allow sudo for applications (e.g., **less**) which might be able to access confidential files like `/etc/shadow`

NOTE: Some Linux/Unix distributions have a default configuration in `/etc/sudoers` allowing root to use **sudo** to run any command as any user:

```
root ALL = (ALL) ALL
```

This does not violate this measure, because it only affects calls to **sudo** from contexts already having unlimited privileges.

If feasible, it is recommended to disable SSH and other logon services in cloud environments, e.g., by using AWS Beanstalk and similar services for system maintenance.

Revision history:

- 3.0: Created new Measure
- 3.1: Describe sudo as a way to implement the concept
- 3.2: Allow ALL in userlist as per example and removed EVAL flag
- 3.3: Allow ALL in the command list for the root user
- 3.5: Avoid elevation of privileges without additional authentication, EVAL flag set
- 3.6: Disable privileged cloud default users or secure these accounts like the root account. EVAL flag set.

3.6.2 Assigning and setting up accounts

S,D

mandatory

Measure M806039, modified on 2016-04-30.

Explanation

User IDs with passwords of insufficient complexity often serve as a major entry point into a system. Once an attacker has gained access, he or she can take advantage of local exploits.

Passwords are not stored directly on a system; instead, a (salted) hash value is stored and used for comparison. For password hashing, the DES encryption algorithm with a maximum password length of 8 characters is used very often. To attain higher levels of security, most systems permit password hashing with other algorithms such as MD5, blowfish, and twofish, where this limitation of the password length does not exist. For password analysis, use of other algorithms than DES may call for reconfiguration of the program **crack**.

The lack of regular password changes, or the reuse of passwords may also pose a risk to system security.

Measure

You must comply with the rules from the generic *Topic-Specific ISEC Policy: Access Control*, [2].

All users must select a password that is at least 8 characters long. Administrative accounts must have a password of at least 15 characters length.

All of the following four components must be included within the password:

- English upper-case letters
- English lower-case letters
- Arabic numerals
- Symbols

Password hashes **MUST** be generated using random salts, if supported by the system. These salts must be unique. If shadowing is supported by the system, then it **MUST** be activated, i.e., there must not exist a single password hash in the passwd file.

If supported by the underlying system, it **MUST** be configured to exclusively allow passwords to be set that are different from the current password and the previous five passwords, i.e., the password history size must be configured to as size greater or equal to five.

The passwords for *administrative accounts* **MUST** be changed regularly. The maximum age for administrator passwords is 30 days. The owner of an administrative account **SHOULD** check in regular intervals if the corresponding password is expired and must change expired passwords. The checks **SHOULD** run in intervals not longer than 30 days.

The passwords for *user accounts* **SHOULD** be changed in intervals no longer than 90 days. The change of user passwords **MUST** be enforced for passwords older than 90 days during the next user login.

For employees who will only be active for a limited period of time, the ID MUST be limited to the same period of time.

According to the *Topic-Specific ISEC Policy: Access Control*, [2], there is another type of account called "Service Account". This account is defined as follows:

Service accounts are a special class of user accounts that are mainly used in the following cases:

- Automatic execution of tasks that are usually performed interactively
- Large scale administration that is based on special administration toolsets (e.g. Frameworks, Netpro)
- Embedded accounts that are used inside complex system setups (e.g. SAP, SharePoint, Database cluster, Server cluster etc.)
- Cross platform communication (e.g. UNIX <-> Windows, JAVA <-> Windows)

For service accounts the password change time period can be extended up to 365 days if all of the following rules are complied with:

- The owner of a service account must be clearly identifiable.
- A current record of all persons who either know or have access to the password or who are able to reset the password has to be maintained by the account owner.
- Unauthorized usage of service accounts must be detected (e.g., by activation and examination of system logs).
- Random passwords must be used that are created from a mixture of upper and lower case letters, numerals and special characters.
- Passwords must be at least 20 characters in length.
- A process for password changes has to be established which includes providing evidence that a password change occurred.
- The account owner has to use available maintenance windows to perform password changes before password expiration.
- System owners and application owners have to provide maintenance windows that allow a timely change of passwords.

Determine the minimum requirements for setting up a new account and carry out these measures for existing accounts as well.

If SSH keys are used for authentication, then password aging can be disabled, if the account does not have a password or is not allowed to login using a password. See Measure 4.3.1 (M505890) and Measure 4.3.3 (M447580) for details about SSH logons.

If the system does not use password based logons (e.g., systems using only SSH keys or cloud installations without logon mechanisms), then no configuration for password length, aging, and complexity is required. On suchlike systems, there must be no account password!

Implementation

The following measures are to be implemented to the degree that they are supported by your system - for future accounts as well as for existing ones:

- To check if all existing accounts with passwords comply, you can use the commands **chage -l <user>** (Linux) or **passwd -r files -s <name>** (Solaris) and correct them if necessary using the same commands. The fifth field in the shadow file corresponds to the account's maximum password age, resp. For AIX you can check the age with **lsuser -a maxage <user>**, this will give you the maximum age in weeks for the password of the user. You can correct the setting with the **chuser** command modifying the *maxage* attribute.
- The length of a password must not be less than 8 characters for user accounts, 15 characters for administrator accounts, and 20 characters for service accounts. Thus, the minimum password length has to be set accordingly (≥ 8 , ≥ 15 , or ≥ 20). For AIX you can check the minimum password length with **lsuser -a minlen <user>**. You can correct the setting with the **chuser** command modifying the *minlen* attribute.
- For AIX you can check the password history with **lsuser -a histsize <user>**. You can correct the setting with the **chuser** command modifying the *histsize* attribute.

General measures that have to be implemented:

- Each user must be assigned a unique user ID.
- Each ID must be assigned to a real person. This is also the case for system IDs such as uucp. When in doubt the operator of the system is responsible.
- Each user UID may be assigned only once.

Check the rights and owners for the configuration files or directory and the files contained therein (Linux: `/etc/pam.d`, HP-UX: `/etc/default/security`, Solaris: `/etc/default/passwd` AIX: `/etc/security`). Owner and group are root in each case. The rights for the directory are 755, the rights for the files 644.

This table shows where to find the parameters mentioned above.

Parameter / OS	Linux	HP-UX	Solaris	AIX
maximum password age	<i>PASS_MAX_DAYS</i> in <i>/etc/login.defs</i>	<i>PASSWORD_MAX_DAYS</i> in <i>/etc/default/security</i>	<i>MAXWEEKS</i> in <i>/etc/default/passwd</i>	<i>maxage</i> in <i>/etc/security/user</i> (for existing users) and <i>maxage</i> in <i>/etc/security/mkuser.default</i> (for default settings for new users)
minimum password length	parameter <i>minlen</i> of <i>pam_unix.so</i> or <i>pam_unix2.so</i> in <i>/etc/pam.d/common-password</i>	<i>MIN_PASSWORD_LENGTH</i> in <i>/etc/default/security</i>	<i>PASSLENGTH</i> in <i>/etc/default/passwd</i>	<i>minlen</i> in <i>/etc/security/user</i> (for existing users) and <i>minlen</i> in <i>/etc/security/mkuser.default</i> (for default settings for new users)
password history	parameter <i>remember</i> of <i>pam_unix.so</i> or <i>pam_unix2.so</i> in <i>/etc/pam.d/common-password</i>	<i>PASSWORD_HISTORY_DEPTH</i> in <i>/etc/default/security</i>	<i>HISTORY</i> in <i>/etc/default/passwd</i> (since Solaris 10)	<i>histsize</i> in <i>/etc/security/user</i> (for existing users) and <i>histsize</i> in <i>/etc/security/mkuser.default</i> (for default settings for new users)

SUSE Linux Enterprise

On SUSE Linux, password hashing has been implemented using the DES method as the standard algorithm. However, this can be changed to MD5 by exchanging the corresponding PAM configuration files. Copy the files from the directory */usr/share/doc/packages/pam/md5.config* into the directory */etc/pam.d*.

Ensure that your authentication applications use the PAM mechanism. Note that this can lead to problems in the case of applications that perform their own authentication via the shadow file.

Red Hat Enterprise Linux

Red Hat Linux currently supports choosing MD5 hashing of passwords as the standard. For this, the entry *USEMD5* must be set to *yes* in the file */etc/sysconfig/authconfig*.

Since version 5.2 Red Hat Enterprise Linux supports the use of SHA-256 and SHA-512 for hashing. It is recommended to use SHA-512:

/usr/sbin/authconfig --passalgo=SHA512 --update

Solaris

On Solaris you can use a stronger password encryption algorithm by changing the parameter `CRYPT_DEFAULT` in the file `/etc/security/policy.conf` to one of the supported encryption identifiers. Following encryption algorithms are supported:

Identifier	Description
1	The MD5 algorithm that is compatible with MD5 algorithms on BSD and Linux systems.
2a	The Blowfish algorithm that is compatible with the Blowfish algorithm on BSD systems.
md5	The Solaris MD5 algorithm, which is considered stronger than the BSD and Linux version of MD5.
5	The SHA256 algorithm. SHA stands for Secure Hash Algorithm. This algorithm is a member of the SHA-2 family. SHA256 supports 255-character passwords.
6	The SHA512 algorithm.
__unix__	The traditional UNIX encryption algorithm. This algorithm is the default module in the <code>policy.conf</code> file.

AIX

On AIX you can use stronger password encryption algorithms by changing the parameter `pwd_algorithm` in `/etc/security/login.cfg` to one of the supported encryption identifiers defined in `/etc/security/pwdalg.cfg`.

NOTE: Please note that after a change of the password encryption algorithm a password is not stored using this new algorithm until the next password change is done!

NOTE: If a user has not logged in until after her or his password expires, a password change has to be forced on the next login.

Revision history:

- 3.1: Major changes, M330320 merged into this measure
- 3.2: Clarify exceptions for passwordless accounts, added information about service accounts, and added AIX specific information.
- 3.3: Requirements for SSH key usage, minor change in implementation of minimum password length
- 3.5: some clarifications in password expiry checking, moved SSH key requirements to Measure 4.3.3 (M447580), added requirement for hash salting, EVAL flag set, references to old Circulars or Corporate Security Policies have been adjusted
- 3.6: Added note about password-less systems.

3.6.3 Built-in IDs

S,D

mandatory

Measure M391200, modified on 2016-04-30.

Explanation

User IDs which are built-in or implemented as standard within a system are often abused by hackers. Many manufacturers supply their systems with standard passwords, which are public knowledge.

Measure

All IDs built in by the manufacturer (both for computers and for add-on software) must be given a new password and assigned to a person with sole responsibility if they are needed for operation.

Alternatively, password based logon may be disabled for suchlike accounts and a SSH key may be assigned. This SSH key has to fulfill the requirements stated in Measure 4.3.3 (M447580).

If an ID is not used, it must be deleted or locked.

Implementation

Check your system to see if there are any standard IDs present and either set a non-standard password, delete or lock the account if possible. Some examples are:

Oadmin, root, admin, sysadm, shutdown, poweroff, guest, demo, gast, informix, oracle, ingres, mgast, sam_exec.

AIX

In addition to the above mentioned users, AIX has the following built-in users in a default installation:

- set `/bin/false` as shell: *daemon, bin, sys, adm, uucp, guest, nobody, lpd, lp*
- check if account is in use by a service - otherwise, also set `/bin/false` as shell: *invscout, snapp, ipsec, pconsole, esaadmin, nuucp*

Revision history:

- 2.2: Minor changes in wording
- 2.3: categorized "mandatory"
- 3.1: Modify measure
- 3.2: Removed EVAL flag and added AIX examples
- 3.6: Added personalized SSH keys as alternative to setting passwords.

3.6.4 Deactivating guest IDs

S,D

mandatory

Measure M905901, modified on 2012-05-31.

Explanation

Various users often share Guest IDs, meaning they cannot be audited. An individual account should be created for each user and assigned only those rights, which are necessary.

Measure

Remove all built-in guest IDs. If not possible, any guest IDs should be given a password and deactivated.

Implementation

The following steps must be implemented on all UNIX/Linux systems.

- Remove built-in guest IDs.
- Avoid using default IDs. Never use IDs such as guest, gast, demo, etc.
- Set a password.
- Use `/bin/false` or better `/dev/null` as a login shell in order to deactivate the IDs.

AIX

For AIX please use `/bin/false` instead of `/dev/null` because AIX does not support `/dev/null`.

Revision history:

- 2.2: Minor changes in wording
- 2.3: categorized "mandatory"
- 3.0: Updated Implementation Section
- 3.2: Added AIX specific information

3.6.5 Automatic Logon

S,D

mandatory

Measure M150034, modified on 2015-05-31.

Explanation

Some UNIX and Linux systems can be configured to login into a console or a windows manager with a pre-configured user account automatically without entering a password. If a system is configured for auto logon, anyone who has physical access to the computer can gain access to all of the computer contents, including any network or networks it is connected to.

Measure

Automatic logon must not be used.

Implementation

During system installation, ensure any settings for automatic logons are disabled. Do not enable automatic logons.

Revision history:

- 3.0: Created new Measure
- 3.1: Removed EVAL flag
- 3.5: Added implementation note

3.6.6 Password-protected screensavers

S,D

mandatory

Measure M300991, modified on 2015-05-31.

Explanation

An attacker could use the absence of the user to gain access to local and network resources. No third-party screensavers (e.g. from the internet) may be used to prevent the danger of introducing Trojan horses.

Measure

When using a graphical user interface, configure an integrated screensaver with password option and set the lock timeout to no more than 15 minutes. To prevent users from overwriting these settings in their user configuration, appropriate notes can be integrated into login messages and/or login windows.

Implementation

Enforce password-protected screen savers according to your desktop environment.

On Gnome-based distributions, e.g. *Red Hat Enterprise Linux 6*, the following commands may be used to enforce mandatory settings for the screensaver:

```
gconftool-2 [--direct] \  
  --config-source=xml:readwrite:/etc/gconf/gconf.xml.mandatory \  
  --type=int \  
  --set /apps/gnome-screensaver/idle_delay 15
```

```
gconftool-2 [--direct] \  
  --config-source=xml:readwrite:/etc/gconf/gconf.xml.mandatory \  
  --type=int \  
  --type=int --set /desktop/gnome/session/idle_delay 15
```

```
gconftool-2 [--direct] \  
  --config-source=xml:readwrite:/etc/gconf/gconf.xml.mandatory \  
  --set /apps/gnome-screensaver/idle_activation_enabled true
```

```
gconftool-2 [--direct] \  
  --config-source=xml:readwrite:/etc/gconf/gconf.xml.mandatory \  
  --set /apps/gnome-screensaver/lock_enabled true
```

Revision history:

- 2.2: Minor changes in wording
- 2.3: categorized "mandatory"
- 2.5: prevent users from overwrite settings
- 3.2: clarification: applies only to GUIs
- 3.4: added implementation section for Gnome
- 3.5: added general hint to implementation note

3.7 Logging

3.7.1 Activating and evaluating logs

S,D	EVAL
	mandatory

Measure M413050, modified on 2016-11-30. **EVAL** flag expires 2017-02-28.

Explanation

Logging offers a means of monitoring and evaluating events on any UNIX system. Such log data must be retained for 90 days. This is especially relevant for DHCP server.

If systems are automatically decommissioned, e.g., in cloud environments supporting elastic sizing, then the logs must be transmitted to a central log collection systems. Otherwise, the log data would be lost.

Measure

Use the following controls for log collection and analysis:

1. Check system activities regularly.
2. Automatically transmit security relevant log data to a log collection system, if the system is running in *cloud environments*, or if the system is subject to *automated decommissioning*.
3. Retain security relevant log files for 90 days. The architecture and sizing of the system and its log collection system **MUST** ensure that security relevant log data is stored in a persistent way for at least 90 days. The required space for log data **MAY** be estimated based on normal system operation.
4. Regularly synchronize log entries to a persistent media, for example a local storage device.

NOTE: Using centralized log collection systems is recommended for all installations. Security relevant logs must include at least the **AUTH** facility.

Implementation

Linux (systemd-based)

The logging on such systems is carried out by **journald**. Enable persistent logging through the parameters *Storage=persistent* and *SyncIntervalSec=1m* within */etc/systemd/journald.conf*. By using the *MaxFileSec* parameter you can adjust the time-based rotation of the journal files. A cryptographic log-sealing using the *journalctl --setup-keys* command and the *Seal=yes* config parameter, is encouraged. Make sure to store the shown seed at a secure location (e.g. encrypted hard disk drive) after setting up the sealing.

Other systems

Have each facility written into its own file and direct all messages to a central syslog server.

Solaris does not deal with messages that are logged to *LOG_AUTH* by default. Therefore you must add the line *auth.info /var/log/authlog* to the file */etc/syslog.conf* to capture this data.

The logs should constantly be checked for specific key words (e.g. `refused|WARN|denied` etc.). This task does not have to be performed on single machines, but can be executed on centralized log analytic systems. If you do not implement an automatic evaluation, the log files must be evaluated at least once per week.

If you suspect that someone has gained unauthorized access to your system (or is attempting to do so), please notify Siemens CERT, preferably via your CERT contact. In an emergency, information on reporting a security incident can be found at <https://www.cert.siemens.com/incidents/> report.

Revision history:

- 2.3: categorized "recommended"
- 2.7: categorized "recommended", added remark regarding retaining logfiles, EVAL flag set.
- 2.9: Removed EVAL flag
- 3.3: Removed obsolete note about max. log retention.
- 3.6: Added requirement for log storage sizing. Added cloud-specific requirements. EVAL flag set.
- 3.7: Added systemd implementation details and sealing suggestions. Renamed title to support all common logging solutions. Enforced "persistent" storage of log entries.

4 Services

4.1 General

4.1.1 Disable all Unnecessary Services

S,D

mandatory

Measure M600310, modified on 2015-05-31.

Explanation

Services running on computers might give attackers a chance to attack a system due to vulnerabilities that have not been patched yet.

Measure

Disable all services that you do not need on your systems. As computer administration methods differ a lot within the company, it is not possible to stipulate which services you can disable in your environment. Furthermore, disabling services may break functionality. You should consider disabling the following services because of security risks (not all of them are running by default):

- ftpd
- dhcpcd
- UUCP
- writesrv (AIX-specific)

Implementation

Implement topics according to the measure section.

Revision history:

- 2.17: Created this measure and set EVAL flag
- 2.18: removed the EVAL flag
- 3.0: categorized as "mandatory"
- 3.1: Removed EVAL flag
- 3.2: Added AIX specific example
- 3.5: Added implementation section

4.2 Base Services

4.2.1 Disable 'R' daemons and Telnet daemon

S,D

mandatory

Measure M300279, modified on 2012-05-31.

Explanation

The 'r' daemons (accessible using the commands **rlogin**, **rsh**, etc.) and the **telnet** daemon offer opportunities to execute commands on a remote system. The major disadvantage of these daemons is the unprotected data transfer. Also authentication by sending unencrypted access data or storing access data in `.rhosts` or `hosts.equiv` files is a high risk. The functionality of these services has to be replaced by the use of the **ssh** or **OpenSSH** service.

The **REXD** service does not offer sufficient security and allows programs to be executed by remote users.

Further the **tftp** service allows data transfer without specific user authentication.

Measure

The use of 'R' daemons, **REXD**, **tftp**, and the **telnet** daemon is not permitted, since these services only support unencrypted data transfer.

These services have to be replaced by the Secure Shell **ssh** or the Open Secure Shell **OpenSSH**.

NOTE: If the **tftp** services is required the secure mode (**tftpd -s**) and a TCP-Wrapper must be used.

NOTE: If the **tftp** service is used in read-only mode and only serves non Siemens-proprietary data (e.g., operating system boot medium or installation software), it is allowed to operate tftp.

Implementation

Deactivate the **telnet**, **rlogin**, **rcmd**, **rexec** and **rwho** services by commenting the corresponding lines in the file `/etc/inetd.conf` or `/etc/xinetd.conf`.

Ensure that no `.rhosts` files still exist and that the file `/etc/hosts.equiv` has been deleted or all input data deactivated.

If the use of 'R' daemons is necessary on particularly important grounds, simultaneous use of the TCP wrappers is called for. It should also be noted that not all Unix operating systems support comments in `.rhosts` files. Regular checks should be performed to ensure that the file `.rhosts` contains no comments.

Revision history:

- 2.3: categorized as "mandatory"
- 2.5: Minor changes regarding comments in .rhosts files
- 3.1: Merged with M420020 and M140202
- 3.2: Allow tftp in read-only mode and if used to serve non Siemens-proprietary data
- 3.3: Removed EVAL flag

4.2.2 Secure Rsync

S,D

mandatory

Measure M835100, modified on 2012-05-31.

Explanation

Rsync is a tool to synchronize files and directories between different systems over an unencrypted network connection per default.

Measure

Although **Rsync** can be started as a daemon (via (x)inetd or standalone), it must be used as a single command in combination with an **SSH** tunnel.

The native **Rsync** authentication is not secure. Transferred data is not encrypted unless **SSH** is used in combination with **Rsync**. Tunneling via **RSH** is not allowed, since the use of 'R' services is not permitted.

Using **SSH**, all **Rsync** traffic is encrypted and only authenticated users are allowed to use **Rsync**.

Implementation

The parameter `-e ssh` must be used to tunnel the **Rsync** traffic. To be able to use **Rsync** it must be installed on both, the source and the destination system.

So you use for example `rsync -e ssh pathto/src dsthost:pathto/dst` to synchronize data between two hosts using an encrypted tunnel (the current user must be able to log into `dsthost`). If you have different users on both systems, use `-e "ssh -l dstuser"` to log into `dsthost` as `dstuser`.

This prevents **Rsync** from being started as a standalone daemon. Furthermore there must not be an entry for **Rsync** in the (x)inetd configuration. On Linux systems, you should also set `RSYNC_ENABLE=false` in `/etc/default/rsync`.

Further information can be found at the following web pages: <http://everythinglinux.org/rsync/>, <http://rsync.samba.org/ftp/rsync/rsync.html>, and <http://rsync.samba.org/ftp/rsync/rsyncd.conf.html>.

Revision history:

- 2.8: Created this measure
- 2.9: Removed EVAL flag
- 3.2: Clarified that the configuration file can exist

4.2.3 Secure NIS

S,D

mandatory

Measure M607590, modified on 2009-10-30.

Explanation

NIS, formerly known as YP (Yellow Pages), is a distributed database system based on the client- server model which was specially developed in order to simplify the administration of a group of networked UNIX machines, but which can also be used for other purposes. Due to its widespread presence on a variety of platforms, it can be viewed as a basic technology for network administration.

Via **NIS**, information is passed to the individual machines functioning as NIS clients, including in particular the central password file, the group file and if applicable the list of keys required for Secure NFS. Operation of an NIS server should be viewed as a security risk for the following reasons:

- All that is needed to submit an inquiry to the NIS server is the NIS domain name.
- No password shadowing is supported within NIS, i.e. the password hash can be queried by each client and, with the aid of tools such as **Crack**, it can be cracked.

For these reasons the operation of NIS domain is *not permitted*. Exceptions are allowed only in the case of test/development cell networks that are completely sealed off.

NIS+ (manufactured by Oracle) represents a secure alternative. Oracle offers **NIS+** as a commercial product for both the Solaris and HP platforms.

Measure

Deactivate **NIS** and migrate to secure solutions such as **LDAPS/Kerberos** or **NIS+**.

Implementation

Deactivate **NIS** and migrate to secure solutions. All current Unix/Linux versions support **LDAPS/Kerberos**. **NIS+** can only be used on Solaris and HP-UX systems.

If despite this you use **NIS** (in accordance with the above restrictions), please note the following:

- Ensure that the domain name used cannot easily be deduced by an attacker.
- Check to see that the domain name is not output by the sendmail daemon with the greeting
- Under Solaris and HP-UX it is possible to limit access on the clients to individual servers or subnetworks with the aid of the file `/var/yp/securenets`. Refer to Manpages for `securenets`.

In order to ensure that clients only connect to valid servers, in the case of HP-UX the file `/etc/yp/secureserver`s can be set up on the clients. The currently valid NIS servers are to be entered here.

Revision history:

- 2.2: Minor changes in wording
- 2.3: categorized as "mandatory"
- 2.5: Added migration note to LDAPS/Kerberos
- 3.0: Minor changes in wording

4.2.4 Secure Internet Daemon

S,D

mandatory

Measure M230501, modified on 2016-04-30.

Explanation

The `/etc/inetd.conf` or `/etc/xinetd.conf` file determines which services are started via the internet daemon. All unnecessary services are to be removed by rendering the commands inactive (by converting them into comments).

If **xinetd** is employed, the access monitoring mechanisms in the configuration file `/etc/xinetd.conf` are to be used to secure the services. If **inetd** is used, the services must be secured via the TCP-Wrapper.

Measure

Implement the following controls for securing the Internet Daemon:

1. Monitor all services started via the **inetd** or **xinetd** internet daemon.
2. The use of **inetd** calls for a TCP-Wrapper.
3. Monitor the access rights of the `/etc/inetd.conf` or `/etc/xinetd.conf` file.
4. The following services are not required, and must be rendered inactive by converting into comments: **echo discard daytime chargen fingerd rexd ruserd time comsat systat netstat sprayd walld**.
5. **tftp** must be disabled unless required and configured according to Measure 4.2.1 (M300279).

Alternatively, ensure that neither **inetd** nor **xinetd** are installed on the system.

Implementation

If **inetd** or **xinetd** is installed, then secure the configuration files by following means:

1. Make sure that the data access rights are set to `644`.
2. The owner must be `root`.
3. Check all started services regarding their use.
4. Render the disallowed and non-required services inactive by converting to comments or explicitly marking them as disabled.

If no service is required, the internet daemon should not be installed. However, for Solaris, the internet daemon is an integral part of the system and cannot be removed.

The **xinetd** daemon is a replacement for the **inetd** daemon and unlike **inetd** has additional security settings. Access authorization, access times, number of servers, redirection and extended logging can be set for each individual service using the extended configuration file `/etc/xinetd.conf`. Using **xinetd** is preferred to using **inetd**.

Revision history:

- 2.2: Minor changes in wording
- 2.3: categorized "mandatory"
- 3.1: changed the file permission.
- 3.2: Removed EVAL flag
- 3.5: Minor change in wording of implementation
- 3.6: Major change in wording, moved banned services from implementation to measure section. EVAL flag set.

4.3 SSH

4.3.1 Secure SSH Server

S,D

mandatory

Measure M505890, modified on 2016-04-30.

Explanation

SSH is a software package comprising a server and multiple clients which can be used as a full replacement for **telnet**, **rlogin**, **rcp** and **rsh**. Unlike **rlogin** or **rsh**, **SSH** does not perform authentication using IP addresses, but instead uses the RSA procedure, among others. Access is only given to computers possessing accepted secret RSA keys. In addition to RSA keys for computers, key pairs for users are also supported. Upon successful authentication, all data is encrypted for transmission, eliminating the possibility of wiretapping. Links through the network from X11 programs to the X11 server can be forwarded via the secure **SSH** link, helping to prevent the wiretapping of **MIT-MAGIC-COOKIES**.

An overview of the advantages of **SSH**:

- RSA authentication capability
- Encrypted data transmission capability
- Replaces insecure commands such as **telnet**, **rcp**, **rsh** and **rlogin**.
- Encrypted X11 forwarding using tunnels

OpenSSH is the new, open source version of **SSH**. Until now, **OpenSSH** is available for Solaris, HP-UX, IRIX, AIX, Linux, and FreeBSD. You can download the current version from the following address:

<ftp://ftp.cert.siemens.com/pub/Unix/Tools/OpenSSH/>

Make sure to check also Security Telegrams referring to **SSH** and **OpenSSH** for supported platforms posted on the Siemens CERT page <https://www.cert.siemens.com>.

Measure

Secure the installed SSH server.

- **SSH** with protocol version 1 must not be used anymore.
- Disable host based authentication.
- Successful and failed logons must be logged for at least 90 days.
- If supported by the SSH server, the log must contain the fingerprint of the SSH key used for a successful logon.
- Logons for the root user must
 - be disabled for clients connecting via public Internet.

- not allow password based authentication, except for clients connecting from a secured management network.

Implementation

NOTE: These are examples for the configuration of the OpenSSH server. There are also other implementations (e.g., SSH) which must be secured accordingly.

To disable protocol version 1, add the line

Protocol 2

to the file `/etc/ssh/sshd_config`.

Host authentication can be disabled by inserting the following lines into the file `/etc/ssh/sshd_config`:

```
RhostsAuthentication no (OpenSSH < 3.7.1)
RhostsRSAAuthentication no (OpenSSH >= 3.7.1)
HostbasedAuthentication no (OpenSSH >= 3.7.1)
IgnoreRhosts yes
```

NOTE: Like the old and no longer permissible file `.rhosts`, the **SSH** equivalent `.shosts` does not support comments.

To disable all logins for the root user, add

PermitRootLogin no

to the file `/etc/ssh/sshd_config` or change the existing entry.

To disable password authentication for the root user, add

PermitRootLogin without-password

to the file `/etc/ssh/sshd_config` or change the existing entry.

The following default settings enable logging of failed and successful logons:

```
SyslogFacility AUTH
LogLevel INFO
MaxAuthTries 6
```

Typically, this setting causes logs to be written to `/var/log/auth`. If the system uses a centralized logging infrastructure, then it is strongly recommended to forward SSH log messages to the centralized log collector.

NOTE: Beginning with version 6.3 OpenSSH logs the fingerprint of the SSH key used for logons.

Revision history:

- 2.19: created new measure for SSH
- 3.0: Removed the eval flag, changed minor wordings
- 3.1: added PermitRootLogin setting
- 3.2: clarify aging policy and removed EVAL flag
- 3.3: minor update in the description of minimum key lengths
- 3.5: moved mandatory parts to the measure section, disallow password authentication for the root user, EVAL flag set
- 3.6: Removed Reliant Unix from list of supported OS. Allowing password based authentication for root from protected networks. EVAL flag set.

4.3.2 Use strong cryptographic algorithms

S,D

mandatory

Measure M447621, modified on 2016-04-30.

Explanation

SSH servers implement a variety of algorithms for encryption, message authentication (MAC) and key exchange.

Some of these algorithms supported by OpenSSH and other SSH server software are considered weak and should not be used anymore.

Measure

Configure the SSH server to not allow weak ciphers, MAC algorithms, or key exchange algorithms.

Therefore, RC4 (also known as ARCFOUR) and single DES must not be enabled in the configuration of the SSH server.

NOTE: Starting with OpenSSH version 6.7, these ciphers are disabled by default.

Implementation

For OpenSSH, the following configuration settings in the file `/etc/ssh/sshd_config` are recommended:

```
Ciphers aes256-ctr,aes128-ctr
MACs umac-64@openssh.com,hmac-sha2-256,hmac-ripemd160,hmac-sha1
KexAlgorithms diffie-hellman-group-exchange-sha256,diffie-hellman-group14-sha1,diffie-hellman-group-exchange-sha1
```

NOTE: Connectivity to legacy systems and systems not supporting any of the ciphers, MACs, or key exchange algorithms listed above, e.g., Exceed 14, may require different settings.

NOTE: If not required by SSH clients, then all algorithms using SHA1 may be removed from the configuration.

NOTE: For OpenSSH, the command **sshd -D -t** can be used to test the configuration. On success, it does not produce any output.

NOTE: It is recommended to deny weak ciphers in the SSH client, too. For OpenSSH, this can be achieved by adding the above-listed configuration to `/etc/ssh/ssh_config`.

Revision history:

- 3.5: Measure created, extended EVAL period set
- 3.6: Removed CBC from the list of weak encryption schemes, minor change in wording.

4.3.3 Requirements for SSH keys

S,D

mandatory

Measure M447580, modified on 2016-04-30.

Explanation

SSH keys provide a login mechanism without transmission of passwords. Consequently, passwords are neither transmitted nor required on the target system. This can remove the need to maintain individual passwords for a user per system.

However, the private key of an SSH key pair allows its owner to access every associated system. Therefore, SSH private keys need to be protected against theft and cryptographic weaknesses. Furthermore, there must be a mechanism to revoke the authorization of compromised keys, because SSH keys can be used by an attacker to gain access to a system despite of password changes.

Measure

Follow these requirements for *SSH key generation*:

- RSA keys must have a key length of at least 1976 bit. A key size of at least 2048 bit is recommended.
NOTE: For ECDSA keys, elliptic curve sizes of at least 256 bits should be used.
- Every key pair must be assigned to a single person known to the corresponding account owner, i.e., persons assigned to the accounts the key is used for.
- Key generation SHOULD not be performed on the server, i.e., any system for which the private key should grant access.

Follow these requirements for *SSH key storage*:

- Private keys must be stored with file permissions 0600 or stricter. The private key must be readable only by its owner or the root user.
- Private keys must be protected with a password. This password has to fulfill the requirements for "Passwords for Service Accounts" according to the *Topic-Specific ISEC Policy: Access Control*, [2], i.e.,
 - The password must be at least 20 characters in length.
 - The password must be changed in intervals no longer than 365 days.
 - Random passwords must be used that are created from a mixture of upper and lower case letters, numerals, and special characters.

A password can be omitted, if all of the following conditions are fulfilled:

- The key is primarily used for automated, unattended maintenance tasks.
- The system storing the private key is exclusively operated in an access controlled environment.
- Any backups of the private key must be protected against unauthorized access.

Follow these requirements for *SSH key entitlement*:

- Inform the owner of the SSH key, if you add the public key to the list of authorized keys.
- If the owner of the SSH key does not have the privileges to remove its public key from the list of authorized keys, then provide a mechanism for revoking keys, e.g., a monitored e-mail address which can be contacted for removal.

Implementation

New keys should be created with a minimum key length of 2048 bit, e.g.,

ssh-keygen -b 2048 -t rsa -C "Full user name and GID" -f outputfile

NOTE: Since brute-force attacks on SSH keys with the recommended length are not feasible for the foreseeable future, no aging policy needs to be implemented.

Often OpenSSH installations create a DSA hostkey with a default length of 1028 bit. The following code can be used to replace this hostkey with a DSA key of 2048 bits:

```
cd /etc/ssh/  
umask 077  
openssl dsaparam -genkey 2048 | openssl dsa -out ssh_host_dsa_key  
ssh-keygen -y -f ssh_host_dsa_key > ssh_host_dsa_key.pub
```

The following command can be used to check the length and type of an SSH public key:

ssh-keygen -l -f path/to/keyfile.pub

The first returned number is the key length in bits.

NOTE: If there are multiple keys in the file, only the first one is checked.

To check the file permissions of RSA private key files, iterate over all home directories and check if the file `.ssh/id_rsa` has permissions of 0600 or stricter and is owned by the owner of the home directory.

NOTE: Private keys can be stored in arbitrary files. Consequently, automatic checks can only cover the default location.

If an RSA private key file in PEM format has a password set, its first two lines should be similar to:

```
-----BEGIN RSA PRIVATE KEY-----  
Proc-Type: 4, ENCRYPTED
```

NOTE: PEM is the default private key format for OpenSSH.

Revision history:

- 3.5: Measure created, prolonged EVAL period defined
- 3.6: Added implementation note on how to create 2048 DSA keys.

4.4 NTP

4.4.1 Time Synchronization

S,D	EVAL
	mandatory

Measure M140306, modified on 2016-11-30. **EVAL** flag expires 2017-02-28.

Explanation

All systems in a network should have the same time. However, individual clocks drift apart unless they are synchronized regularly. If different systems had different times, log files are difficult to be compared. Moreover, there are protocols that rely on a synchronized time and fail if systems drift away from each other too much. Therefore, time synchronization is an important issue that adds to the security of an infrastructure.

The standard to synchronize time is via the Network Time Protocol (NTP).

Measure

You must enable time synchronization. Synchronize the time of the system clock with a trusted source like a Siemens-internal domain controller, Siemens-internal NTP servers, DCF77 receivers, GPS receivers, or the hypervisor for virtualized systems. You should use authentication if applicable and available.

The time must be consistent on every system, i.e., for each individual system, all log entries of all log files must be based on the same time zone. The chosen time zone has to be known by the system administrators.

Implementation

Ideally, any system should synchronize with at least 3 time servers of Stratum level 2 or 3. If this cannot be achieved, synchronize with the lowest Stratum level available to you. Choose time server that are located close to you (in terms of network delay).

Usually, your service provider (e.g., Atos for all GAIN systems), provides access to Stratum-2 or Stratum-3 NTP servers. Due to frequent changes in the NTP infrastructure (old servers are migrated to new IP addresses and additional NTP servers are added to the pool), Siemens CERT provides details about how to find a suitable NTP server at <https://www.cert.siemens.com/faq/network/NTP>. You should check this page regularly to be able to react on infrastructure and governance changes.

There are several ways to implement this measure. For example, you can call **ntpd** or **rdate** daily via **cron** or you can use daemons such as **xntpd** or **openntpd**.

On Linux systems using **systemd**, a SNTP client called **datetimed** is shipped by default. Note that this daemon does not use drifting. Due to this, the clock is not adjusted by using small steps but within one big step. Mail servers and other time-critical services might stop working when using such a time-synchronizing strategy. Standard services like webserver or standard desktop clients are usually not harmed by such a hard adjustment of the internal clock, though. Also note that SNTP is a simplified version of NTP and thus not recommended in environments where high accuracy timing is needed.

Revision history:

- 3.0: Modified Measure and included FAQ site with NTP server information
- 3.1: Categorized. EVAL flag removed. 2 time servers are enough.
- 3.4: Added Siemens-internal domain controllers, DCF77 and GPS
- 3.6: Added hypervisor-based time synchronization
- 3.7: Added systemd implementation details

4.4.2 Network Time Protocol Daemon

S,D EVAL

mandatory

Measure M447886, created on 2016-11-30. **EVAL** flag expires 2017-02-28.

Explanation

Poorly configured Network Time Protocol (NTP) daemons can be easily used to carry out distributed denial of service (DDoS) attacks. As NTP is typically used on top of UDP, an attacker can send requests using a spoofed source IP address of a victim. Doing so tricks poorly configured NTP daemons to unknowingly participate in a DDoS attack. Typically, the `monlist` NTP command is used for such attacks, as it results in answers containing big payloads.

In most environments there is no need for a globally reachable NTP daemon. Siemens already provides a NTP infrastructure. In-depth information about the Siemens NTP infrastructure be found at <https://www.cert.siemens.com/faq/network/NTP>.

Measure

Disable server functionalities of all Network Time Protocol (NTP) suites upon your system.

Exception

When there are technical or organizational issues that require the operation of an own NTP daemon, only an approach which serves to a strictly limited amount of known clients is allowed. Additionally, the `monlist` command must be disabled on the NTP daemon whenever technically possible.

Implementation

Use NTP clients without server-component, like `systemd-timesyncd`, on your Linux host. Alternatively, install a NTP daemon and restrict access to its server-components with appropriate measures, for example using appropriate daemon configuration settings or network based access control rules.

If you need to operate a NTP daemon, make sure to only allow selected IP ranges or clients to access the server. In order to disable the `monlist` command, add the `noquery` directive to the `restrict default` line in the system's `ntp.conf`.

Revision history:

- 3.7: Created new measure
This change was submitted after the review phase: Reworded measure to include disabling of NTP suites as well.

4.5 SNMP

4.5.1 Secure SNMP Server

S,D

mandatory

Measure M840320, revised on 2015-05-31.

Explanation

SNMP is a standard protocol to monitor the configuration and health of a system. It also offers the feature to change configuration settings.

There are three versions of SNMP: SNMPv1, SNMPv2, and SNMPv3. Actually, three versions of SNMPv2 have been defined in RFCs, SNMPv2p, SNMPv2u, and SNMPv2c. Since virtually only SNMPv2c is used in practice, SNMPv2 is used synonymously with SNMPv2c.

The two versions SNMPv1 and SNMPv2 are insecure, because they contain no authentication, or transmit access credentials (a.k.a. "community strings") in clear text. Therefore, using SNMPv1 or SNMPv2 poses a threat to the network, as an attacker may gain important information about the affected devices, or even administrative access.

Measure

You must replace SNMPv1 and SNMPv2 by SNMPv3.

Disable **snmp** service or ensure that you use a community string which is hard to guess.

Exception for current deployments

New devices must be capable of handling SNMPv3, or SNMP must not be used. Current hardware and software deployments at Siemens (including management software) do not have to be replaced.

Exception for SNMP GET for data classified as "Restricted"

Some devices allow to restrict connections initiated via SNMP to only read out data from the device, but not to change any data on that device (i.e., using only the SNMP GET community, or read-only community). If the administrator restricts the data accessible via SNMP GET in such a way that all data available is classified at most as "Restricted", and access is only possible from the Siemens intranet, SNMPv1, SNMPv2, and SNMPv3 without authentication and encryption may be used. Note that such data must not include configuration data, since *"configuration files must be handled confidentially"* according to the *Topic-Specific ISEC Policy: Operations Security*, [4]. Generally, this exception only applies, if all data accessible via SNMP GET (regardless of the community string setting and distribution) could just as well be displayed on a web page accessible for everyone using the Siemens intranet.

Exception for SNMP GET for special network zones

GET commands (i.e., the read-only community) of SNMPv1, SNMPv2, and SNMPv3 without authentication and encryption may be used in special network zones, if SNMP traffic is not allowed to traverse the filtering device, and a risk assessment has been performed and was approved by an InfoSec responsible. Common scenarios for this exception are SNMP traffic in a firewalled data center, SNMP traffic within an encrypted tunnel connecting data centers, and traffic containing only data classified at most as

"Restricted" routed in clear text over the WAN.

Exception for SNMPv3 SET for data classified as "Restricted"

If SNMPv3 allows to access data, and all of that data is classified at most as "Restricted", SNMPv3 SET traffic may be used with authentication only (i.e., without encryption), if access is only possible from the Siemens intranet. Note that such data must not include configuration data, since *"configuration files must be handled confidentially"* according to the *Topic-Specific ISEC Policy: Operations Security*, [4], Section 4.4.2. Generally, this exception only applies, if all data accessible via SNMP GET (regardless of the community string setting and distribution) could just as well be displayed on a web page accessible for everyone using the Siemens intranet.

Technically Impossible

If in a certain scenario, the available hardware does not offer SNMPv3 as an option, and it is therefore technically impossible to use SNMPv3, SNMPv1 and SNMPv2 may be used. Note that this exception does not apply if a device is deployed due to business considerations, when a SNMPv3-capable device would be available instead.

Implementation

Please check to see whether the **SNMP** service is actually necessary.

If the **SNMP** agent is required, you must ensure that the default community strings *"private"* and *"public"* are changed to something non-trivial.

AIX

You can set the **SNMP** daemon version according to the above described scenarios with the following command: **snmpv3_ssw -n** (-n non encrypted V3, -e encrypted V3, -1 snmpv1)

Revision history:

- 2.3: categorized as "mandatory"
- 2.15: categorized as EVAL and prohibited the use of SNMPv1 and SNMPv2
- 2.16: removed EVAL flag
- 3.0: Minor changes in wording
- 3.1: Changed the measure to allow SNMP v1 and v2 in certain circumstances.
- 3.2: Removed EVAL flag and added AIX-specific information
- 3.3: Minor changes in wording
- 3.5: references to old Circulars or Corporate Security Policies have been adjusted

4.6 Mail Transfer Agents

4.6.1 Secure Mail Transfer Agent Daemon

S,D

mandatory

Measure M402440, modified on 2016-11-30.

Explanation

A message transfer agent (MTA) is a mail server like Sendmail or Postfix that includes a daemon listening to SMTP ports. Such a daemon is not needed for mail clients that receive mails from IMAP or POP3 servers nor is it needed for applications that send e-mail via SMTP. Every MTA is part of Siemens' messaging infrastructure and therefore must be properly configured.

If the system is running as mail server, the latest version of this mail server software has to be used. Additionally, the mail server must not unrestrictedly relay mails! If the mail server receives or transmits messages to a non-local network, then it should support encrypted transmissions.

Measure

When it is not necessary to operate the system with a MTA for sending and receiving emails (e.g., local desktops system), you must either deactivate the mail daemon or configure the mail daemon to deactivate the receive mode for non-localhost network interfaces.

Use only the most up-to-date mail daemon version on mail servers.

A mail server configured in such a way that it allows remote computers on a non-local network to send e-mail through it must support transport layer security (e.g., via STARTTLS) for incoming and outgoing connections, and valid certificates must be set up.

All encrypted connections from or to the mail server must use TLS instead of SSL.

You must restrict the list of other mail servers or mail clients that should be able to relay mails using your mail server. This can be achieved using SMTP authentication or a list of relay hosts based on the DNS name or IP address. The MTA must not permit any plaintext password mechanisms during SMTP authentication unless the connection is secured, e.g., after a successful STARTTLS command.

Implementation

General

In order to minimize the risks resulting from **sendmail** daemon, you can use **Smrsh**. If it is necessary to use **sendmail**, the following things must be checked:

- Use only the latest version of sendmail (at least the latest version released by the manufacturer). Previous versions have deficiencies, some of which are serious, that allow an attacker to access root privileges. You can find the latest version at <ftp://ftp.cert.siemens.com/pub/Unix/Tools/sendmail/>.

New versions of **sendmail**, as well as manufacturer releases, will be announced at <https://www.cert.siemens.com/> and security patches for supported platforms will be announced by Security Telegrams.

- Deactivate the *VRFY* and *EXPN* commands.

The *goaway* option is standard for **sendmail** as of Version 8.8.

- Use the command **telnet localhost 25** to ensure that **sendmail** does not output the name of your NIS domains with the greeting (standard on some older Oracle Solaris installations).

On systems which do not receive mails, the **sendmail** daemon command in the start script (`/etc/init.d/sendmail`) should be modified. The following change to the start script ensures that it is not possible to receive mails via the mail daemon.

`/usr/lib/sendmail -bd -q15m & → /usr/lib/sendmail -q15m &`

In the above example, mails in the mail queue continue to be sent every 15 minutes. As an alternative to this solution, the sendmail daemon start-up can be cancelled.

NOTE: For proper handling of replies and bounces, it is advisable to set a different sender address, e.g. the personal email address of the system administrator.

Mails from the mail queue can also be sent regularly by a cronjob. With Solaris the command **sendmail -q** is called up once a day at 23.30 hrs by cron-job by inputting `30 23 * * * /usr/lib/sendmail -q` in the file `/var/spool/cron/crontabs/root`.

SUSE Linux Enterprise

Under SUSE Linux Enterprise, the *SMTP* variable in the file `/etc/rc.config` must be set to *yes* and in the configuration file `/etc/rc.config.d/sendmail.rc.config` the *SENDMAIL_ARGS* variable set to *-qm30*.

Red Hat Enterprise Linux

With Red Hat, the configuration file `/etc/sysconfig/sendmail` needs the following inputs:

- *DAEMON=no*
- *QUEUE=30m*

Solaris

To configure sendmail for only delivering on localhost the following steps must be taken:

```
svccfg -s svc:/network/smtp:sendmail setprop config/local_only = true
svcadm refresh svc:/network/smtp:sendmail
svcadm restart svc:/network/smtp:sendmail
```

To disable sendmail completely you can disable the two sendmail identifiers:

```
svcadm disable svc:/network/sendmail-client:default
svcadm disable svc:/network/smtp:sendmail
```

AIX

N/A

Revision history:

- 3.2: add note about adjusting sender address and added AIX-/Solaris-specific information
- 3.4: moved requirements for malware scanning to Measure 3.4.1 (M250305)
- 3.5: use TLS instead of SSL for transport encryption, clarification about encrypted mail transfer, major rewrite of the measure, fixed spelling error in RedHat implementation note, EVAL flag set
- 3.7: removed issue affecting only Reliant Unix from implementation section, no need to set EVAL

4.7 IMAP and POP3 Server

4.7.1 Secure IMAP and POP3

S,D

mandatory

Measure M784009, modified on 2009-10-26.

Explanation

The services **POP3** and **IMAP** can be used by clients to load mails from servers. The ID and password for user authentication are transmitted in unencrypted form. In the past, the **POP3** and **IMAP** services often revealed serious security vulnerabilities.

Measure

For the data link from the mail server to the mail client, you should use only secure connections. Deactivate the services **POP3** and **IMAP** or replace them with the **POP3S** and **IMAPS** services secured with SSL.

Implementation

Check whether the **POP3** or **IMAP** services are necessary for operation. Replace these services with versions that permit secure SSL connections.

Check that both the clients and server allow SSL links.

Ensure that no unencrypted links to the server are established by analyzing the network traffic from/to the server.

The protocol **POP3** normally employs ports 109 and 110 for its connections. Port 995 is reserved for secure connection with **POP3S**.

The protocol **IMAP** uses ports 143 and 220 for network connections. Port 993 is reserved for secure connection with **IMAPS**.

If the used **IMAP** or **POP3** server does not support **POP3S** or **IMAPS**, it is mandatory to use **stunnel**. **Stunnel** provides secure encrypted connections by using TLS/SSL.

Revision history:

- 2.3: categorized as "mandatory"
- 2.15: added stunnel
- 3.0: Minor changes in wording

4.8 Webserver

4.8.1 Protecting Web Server

S,D

mandatory

Measure M410802, modified on 2015-05-31.

Explanation

Web servers allow access to files and directories from the intranet and internet. In line with the many possibilities provided by web servers, the risk potential is also very significant.

Under UNIX, Apache is one of the servers used most frequently. Ensure that in each case the current version is installed with the appropriate security patches.

Measure

Secure your web server.

In accordance with the *Topic-Specific ISEC Policy: Cryptography*, [3], every web server on the intranet must support the **HTTPS** protocol, i.e., SSL/TLS (see policy for exceptions).

If no web server is required on a system, make sure that no web server will be started.

If a web server is required, implement the Siemens CERT "Measure Plan for Apache on Unix and Windows" (see <https://www.cert.siemens.com/rules/webserver>). If a web server other than Apache is used, the measure plan must be adapted and implemented accordingly to achieve the same security level.

Scan dynamic and static web content for viruses as required by Measure 3.4.1 (M250305).

Implementation

Check whether a web server (port 80) has been started on your system.

If no web server is required, ensure that this service is not being started.

If a web server is activated, secure installation and configuration must be ensured.

The Siemens CERT "Measure Plan for Apache on Unix and Windows" (see <https://www.cert.siemens.com/rules/webserver>) has to be implemented.

The *Topic-Specific ISEC Policy: Cryptography*, [3] must be observed.

For web servers which offer their services in the Siemens Intranet, and which are therefore equipped with certificates of the type *TCID* (as issued by the Siemens Trust Center via the Server Registration Authority), strong encryption (128bit and higher) for SSL/TLS-sessions has to be enforced. For all other scenarios, strong encryption should be enforced as well, if possible.

Furthermore, please note that due to several security flaws in SSLv2, Siemens CERT recommends to disable this protocol on all web servers.

Revision history:

- 3.0: Minor changes on the wording; Removed the outdated SSLScan tool
- 3.4: updated link to CIT circular
- 3.5: added reference to Measure **3.4.1** (M250305), updated name of "Measure Plan for Apache on Unix and Windows", EVAL flag set, references to old Circulars or Corporate Security Policies have been adjusted

4.9 NFS and RPC

4.9.1 Configure NFS

S,D

mandatory

Measure M478100, modified on 2016-04-30.

Explanation

Exports without restrictive access control enable downloading confidential information and import of malicious software.

Measure

Shared folders must have access control.

The rights to all exported folders must be checked regularly (at intervals of no more than 90 days), in order to determine whether access is limited to authorized network users and groups. The export of folders must be documented with source system, target system(s) and net group.

Implementation

If NFS is used at your location, please proceed via the following measures:

- Make sure that the access rights for the file `/etc/exports` (`/etc/dfs/dfstab` for Solaris) are set to `644` and that the owner is `root`.
- If possible only allow read-only access to your exported data (`-ro`)
- Do not export either the root folder `/` or `/etc`
- Carry out regular checks to ensure that your folders are only being exported to dedicated computers. (e.g., `-access=host.domainname`)
- Also check the exported folders externally using **showmount -e <computer name>**
- Deactivate NFS, if you do not wish to export any file systems.
- As far as possible, use the `-nosuid` option for mounting folders, to prevent execution of setuid programs.
- Use the option `anon=-1` to completely disable anonymous access.
- Check that the file `/etc/exports` (`/etc/dfs/dfstab` for Solaris) does not contain the options `no_root_squash`, `maproot`, `root`, or `anon=0` to prevent access with UID 0 to NFS file systems. Root access to NFS shares must only be granted via a separated network interface (e.g., admin network).

NOTE: If you are using NFS shares to serve non Siemens-proprietary data, such as operating system installation mediums, anonymous access may be allowed and therefore the parameter `anon` may be set to the value 0. E.g., Jumpstart only works with this setting.

Revision history:

- 2.2: Minor changes in wording
- 2.3: categorized as "mandatory"
- 2.12: don't access NFS shares with UID 0
- 3.0: Minor changes in wording
- 3.1: NFS export on localhost is no security risk anymore
- 3.2: Clarification about net group instead of user group and added exception for anonymous NFS access
- 3.6: Removed Reliant Unix from implementation note.

4.10 Samba

4.10.1 Secure Samba Server

S,D

mandatory

Measure M602600, revised on 2015-05-31.

Explanation

Samba is a program that enables the users of Windows operating systems to access folders in UNIX systems. Here, the authentication of access can be via a user ID and password or anonymously via a guest ID. A separate password file `/etc/smbpasswd` is used for authentication purposes. Alternatively, authentication can also be via one or more password servers.

In order to prevent unauthorized eavesdropping on the password, the passwords must be transferred in encrypted form.

To protect the shared files from misuse, the data should be shared for reading only if possible, or for the relevant users or systems only. Anonymous users must not be able to enumerate shared files or folders.

In the default configuration **Samba** is prone to a symlink attack, as it allows clients using the UNIX extensions to create symlinks on remotely mounted shares on which they have write access that point to any path on the file system. UNIX clients will resolve these links locally, but Windows clients will resolve them on the server.

Measure

The root folder `/` and the folder `/tmp` must not be shared.

Shared folders must have access control.

The transfer of passwords for authentication must take place using encryption.

Shared folders must not be anonymously browsable.

If a local user management (e.g., `smbpasswd`) is used for authentication, the *Topic-Specific ISEC Policy: Access Control*, [2] must be implemented for these accounts.

Wide links must be disabled in the configuration.

Implementation

If **Samba** is installed on your system, please check the following settings in the file `smb.conf`:

- The global parameter `encrypt passwords = yes` must be set
- The global parameter `security = share` is prohibited
- The parameters `browseable = no`, `restrict anonymous = 2`, `null passwords = no` and `guest account = <username>` prevent representation of the folder shares in

search lists or folder names being read out by means of null sessions. Create a new group and a new user for **Samba**. The default group for the user must be the new created group and the default login shell must be `/bin/false`. The parameter guest account should be mapped to the new created user. Further, for every share use the parameter `guest ok = no` to prevent accessing the share without password. The parameter `map to guest` must be set to `NEVER`.

- If folders are shared with `guest ok = yes`, it should be ensured that access is restricted to selected networks or systems only. This can be implemented with the parameters `hosts allow`, or `hosts deny`.
- Set the global parameter `server string = ""`. This prevents the **Samba** Version currently in use being passed on.

The following **Samba** configuration is a recommendation how to implement the above described options:

```
[global]
workgroup = <domain>
realm = <domain>.SIEMENS.NET
netbios name = <GNSHOSTNAME>
encrypt passwords = yes
map to guest = NEVER
security = ads
password server = *
name resolve order = bcast host
restrict anonymous = 2
null passwords = no
guest account = smb_nobody
use spnego = yes
client use spnego = yes
server string = ..
host msdfs = no
msdfs root = no
domain master = no
preferred master = no
local master = no
os level = 0
browse list = no
dns proxy = no
wide links = no
```

```
[share_test]
path = /home/test/share
guest ok = no
read only = no
browseable = no
```

The following should also be kept in mind:

- The owner of the file `/etc/smbpasswd` is root. The access rights of the file are set to `644`.
- Shares with write access must be within a separate partition.

- Monitor your shares on a regular basis using an additional system. Linux offers the following command **smbclient //Server/release**. In a Windows command line use **net use \\Server\ipc\$ "password" /user:"username"; net view \\Server**.

If Windows clients want to access shares on a **Samba** server, you should restrict the access to the **IPC\$** share. This allows you to offer access to other shares while denying access to **IPC\$** from potentially untrustworthy hosts.

[ipc\$] hosts allow = 192.168.115.0/24 127.0.0.1 hosts deny = 0.0.0.0/0

You can also restrict access to shares for usernames and groups.

[IPC\$] valid users = +group, user

Revision history:

- 2.1: Changed "Samba configuration file" to "smb.conf"
- 2.2: Corrected Windows command line. Minor changes in wording
- 2.3: categorized as "mandatory"
- 2.7: Added note about authentication against a Windows Domain or the Active Directory
- 2.10: Uploaded files must be checked for viruses.
- 2.12: check VCC regulations, whether a virus scanner is needed
- 2.17: updated nullsession and IPC\$ share protection
- 2.18: added the parameter map to guest
- 2.19: removed Samba2 options, changed parameter value
- 2.20: updated example; removed EVAL flag
- 3.0: Removed the SWAT implementation part
- 3.1: Mention forbidden anonymous enumeration of shares in explanation and measure section; protect against symlink attacks
- 3.2: Removed EVAL flag
- 3.4: moved requirements for malware scanning to Measure **3.4.1** (M250305)
- 3.5: references to old Circulars or Corporate Security Policies have been adjusted.

4.10.2 Configure Samba Server in Active Directory Environment

S,D

mandatory

Measure M830304, modified on 2012-05-31.

Explanation

Siemens mostly use Active Directory mechanisms to access file shares and authenticate the user. Samba allows to be a member of an Active Directory and uses these authentication and access mechanisms.

Measure

If your Samba server is part of the Siemens Active Directory forest, it is mandatory to setup the Samba server to be compatible to Windows Group Policy settings. Further, if shares are read and writable, it must exist a one to one mapping of the user account. This means one Active Directory user account must be mapped to one UNIX user account.

Implementation

If user authentication against a Windows Domain or the Active Directory is used, please note:

- The recommended way to do this is to use Samba3 with the option *security = ads*. NOTE: ADS can only be used when the Kerberos package is installed.
- Samba3 with option *security = server* has got problems with NTLMv2 authentication. Since Windows clients have to use at least NTLMv2 now, one of the options *ads*, *domain* must be used must be chosen. Otherwise these clients would not be able to connect to the Samba server.

Revision history:

- 3.0: Created this measure
- 3.1: Categorized as mandatory
- 3.2: Clarification when the measure must be implemented
- 3.3: Removed EVAL flag

4.10.3 Avoid the Samba Web Administration Tool (SWAT)

S,D

mandatory

Measure M107290, modified on 2015-05-31.

Explanation

The **Samba Web Administration Tool** (SWAT) is a web based configuration tool provided by **Samba** that enables local and remote configuration management. It is not installed by default. It must not be used because it requires a Samba administrator account and sends that password in clear text over a network connection.

Measure

Disable the **SWAT** service and remove it.

Exception

If you require to run **SWAT**, limit the access to the local machine or tunnel SWAT connections through SSL (e.g., with **stunnel**).

Implementation

Check that the SWAT tool is not installed.

Revision history:

- 3.0: Created the measure
- 3.1: Removed EVAL flag
- 3.2: Change measure number to resolve conflict with SAP MP
- 3.5: Added implementation hint

4.11 FTP

4.11.1 Configure FTP Daemon

S,D

mandatory

Measure M200290, modified on 2008-03-31.

Explanation

The **FTP** service allows interactive file transfers to and from a system. Authentication and data transfers are unencrypted. This service therefore also allows the unencrypted transfer of confidential information. In addition, it is also possible to upload and execute exploit code.

Measure

The **FTP** file transfer service has to be replaced by the **SSH** or **OpenSSH** service. Exceptions are permitted only in the case of anonymous FTP servers.

Implementation

- Deactivate the service by commenting out the corresponding lines in the file `/etc/inetd.conf` or `/etc/xinetd.conf`.
- For file transfer, replace **ftp** with **scp** or **SFTP**. The client **scp** is a component of the **SSH** or **OpenSSH** software. **SSH File Transfer Protocol (SFTP)** is a network protocol that provides file transfer functionality.
- If large files need to be exchanged, the Secure File Exchange offered by Siemens (see <https://secufex.erlm.siemens.de/>) can be used as well. This service also allows exchanging files with customers and partners.

Revision history:

- 2.3: categorized as "mandatory"
- 2.15: added SFTP and SecuFex as alternatives
- 2.16: corrected link to SecuFex service

4.11.2 Secure Anonymous FTP

S,D

mandatory

Measure M296020, modified on 2016-04-30.

Explanation

The secure operation of anonymous FTP servers is not trivial and therefore to be kept to the absolute minimum. Incorrectly configured FTP servers can pose a serious threat to the security of a Unix system.

Measure

Secure the anonymous FTP service.

The following security controls shall be implemented:

1. Ensure that the used software version of the FTP server software is still supported by its vendor.
2. FTP servers accessible from the Internet have to be completely read-only!
3. The FTP server software must not support the "SITE EXEC". Alternatively, the command must be guarded additional security controls to prevent arbitrary command execution.
4. The rights for the FTP home must be set to 555 and the owner has to be root or a special ftp admin user (not the user ftp!).
5. The system configuration and other sensitive files (e.g., /etc/passwd or /etc/shadow) must not be accessible via FTP.
6. If you want to enable users to upload files, make sure that the access rights of the upload directory (typically ftp/incoming/) are set to 1733 and the owner is root or a special ftp admin user (not the user ftp!). This way, files cannot be downloaded directly from this directory. The reason for this is to prevent an illegal software exchange. All uploaded files have to be checked with an up-to-date antivirus software before being moved to a special download directory (typically ftp/outgoing) or regular folders under ftp.

Implementation

It is recommended to use an FTP server software from the operating system distribution to implement control (1).

To implement control (2), consult your FTP server software manual. No upload directories are allowed. If necessary, data has to be supplied using secured file transfers (e.g., scp) from the Intranet.

For control (3), it is recommended to disable the "SITE EXEC" command. You may use the following commands for this check:

```
telnet localhost 21 USER <username> PASS <password> SITE EXEC
```

A <5xx> error message should appear as a result. If you do not see an error message, and "SITE EXEC" is not completely disabled, the ftpd must be replaced with a newer version.

Checking control (4) can be achieved by verifying the ownership and access rights of the FTP directory or by trying to write to that directory with a user other than ftp or root. This write attempt must fail.

Ensure that there is no copy of your system configuration files or even sensitive data (e.g., /etc/passwd or /etc/shadow) in ftp in order to implement control (5).

The controls of this measure represent only the minimum requirements for an FTP service within Siemens and should under no circumstances be considered complete.

Further information on the secure operation of an Anonymous FTP service can also be found at the following address:

ftp://ftp.cert.siemens.com/pub/Information/Advisories/cert/cert_tips/anonymous_ftp_config

Revision history:

- 2.2: Minor changes in wording
- 2.3: categorized as "mandatory"
- 2.5: More details regarding the use of download and upload areas; FTP servers accessible from both the Intranet and the Internet have to be read-only
- 2.9: Removed statement regarding wu-ftp
- 2.10: Uploaded files must be checked for viruses
- 2.12: check VCC regulations, whether a virus scanner is needed
- 2.16: clarified SITE EXEC statement and other minor changes in wording
- 3.0: Removed the links to the superseded Security Telegrams
- 3.6: Moved mandatory controls to the measure section. Major change in wording. EVAL flag set.

4.12 X Server

4.12.1 Restricting X Server Access

S,D

mandatory

Measure M420460, modified on 2004-12-08.

Explanation

With an unprotected X Server it is possible for an attacker to read the keyboard entries or screen contents across the network.

Measure

Restrict access to your X Server.

Implementation

Use at least IP-address-based access protection procedures such as **xhost** (see **xhost(1)**). Cryptologic access protection procedures such as *MIT-MAGIC-COOKIE* (see **Xserver(1)**) are desirable. Access protection using *MIT-MAGIC-COOKIE* is set via **xauth** (see **xauth(1)**).

In order to be sure that at least **xhost** authentication is switched on, please use the following command:

xhost

A text to the following effect should appear in response:

access control enabled, only authorized clients can connect

To allow access please enter the following:

xhost +user@computername

The use of the command **xhost +** without corresponding options is forbidden.

If the XServer is only used locally, the option *-nolisten tcp* is employed when calling the Xserver to prevent it being accessible via the network.

Under Linux, the XServer is normally started by the display manager **xdm**. The addition of the option *-nolisten tcp* in the line with the call options for the Xserver in the file */etc/X11/xdm/Xservers* prevents network access to the XServer via port 6000.

If X11 connections are required, then **SSH** may be used. This tool enables encrypted X11-connections. To enable this functionality, the variables *X11Forwarding* in the file */etc/ssh/sshd_config* and *ForwardX11* in the file */etc/ssh/ssh_config* have to be set to yes. If an **SSH** Secure Shell client is used on a Windows system, the X11 option tunnel must be activated there. The Xserver on the Windows system requires access to *localhost*. If **EXCEED** is used, the line *localhost* must be entered in the file *xhost.txt*.

The Xserver on the Windows system is to be secured in the same manner as described above. Further information can be obtained from the Siemens CERT at the following address: https://www.cert.siemens.com/faq/entries/secure_x_server

Revision history:

- 2.1: Corrected "X11Forward" to "ForwardX11" and added full paths to the SSH configuration files
- 2.3: categorized as "mandatory", updated link to X11 information
- 3.0: Minor changes in wording
- 3.3: Minor changes in wording of the implementation section

5 Checklist

An editable Security check sheet in Excel format can be found at

https://www.cert.siemens.com/rules/policy/CERT_UNIX_Linux_Security_Check_Sheet.xls

System name: _____

Chapter No.	Measure No.	Measure	H/S/W flag	Done
General - Physical Security				
3.1.1	M729001	Protecting physical interfaces	D	
3.1.2	M680620	BIOS Settings - Boot and BIOS Passwords	D	
3.1.3	M201280	Boot Sequence, Multi Boot	D	
3.1.4	M338090	Prevent unauthenticated Boot	S	
3.1.5	M700351	Secure Built-in Remote Management Interface	S,D	
3.1.6	M112800	Protecting Linux Bootmanager with password	D	
3.1.7	M950630	No Biometric Authentication Devices	S,D	
3.1.8	M800954	Disable Firewire (IEEE1394)	D	
General - Installation and Maintenance				
3.2.1	M603120	Operating system version	S,D	
3.2.2	M497003	Applying security patches	S,D	
3.2.3	M653700	Siemens CERT Security Telegrams	S,D	
3.2.4	M447301	Install Corporate Scan Service Software Agent	S,D	
General - Local Security				
3.3.1	M505607	Enable Stack Protection	S,D	
3.3.2	M447734	Enable link protection	S,D	
3.3.3	M604007	Disable Core Dumps	S,D	

Chapter No.	Measure No.	Measure	H/S/W flag	Done
3.3.4	M200587	Protect Single User Mode with Password	S,D	
3.3.5	M730750	Setting Umask	S,D	
3.3.6	M608700	Scheduled service security	S,D	
3.3.7	M802906	Protecting System Files	S,D	
3.3.8	M406350	Home folders	S,D	
3.3.9	M805036	Links in the folder /tmp	S,D	
3.3.10	M509730	Existing user and group for all files	S,D	
3.3.11	M812040	Monitoring SUID and SGID files	S,D	
3.3.12	M809740	Disable Automount and Autorun	S,D	
3.3.13	M700784	Preventing shutdown without login	D	
3.3.14	M447647	Secure Configuration Files	S,D	
General - Malware Protection				
3.4.1	M250305	Standard Virus Scanner	S,D	
3.4.2	M447203	Special Virus Scanner	S,D	
General - Network Security				
3.5.1	M202900	Check active Network Connections	S,D	
3.5.2	M307609	Disable Unneeded Network Protocols	S,D	
3.5.3	M740601	Securing Bluetooth	S,D	
General - Account and Access Control				
3.6.1	M910080	Concept of Least Privileges for Users	S,D	
3.6.2	M806039	Assigning and setting up accounts	S,D	
3.6.3	M391200	Built-in IDs	S,D	
3.6.4	M905901	Deactivating guest IDs	S,D	
3.6.5	M150034	Automatic Logon	S,D	

Chapter No.	Measure No.	Measure	H/S/W flag	Done
3.6.6	M300991	Password-protected screensavers	S,D	
General - Logging				
3.7.1	M413050	Activating and evaluating logs	S,D	
Services - General				
4.1.1	M600310	Disable all Unnecessary Services	S,D	
Services - Base Services				
4.2.1	M300279	Disable 'R' daemons and Telnet daemon	S,D	
4.2.2	M835100	Secure Rsync	S,D	
4.2.3	M607590	Secure NIS	S,D	
4.2.4	M230501	Secure Internet Daemon	S,D	
Services - SSH				
4.3.1	M505890	Secure SSH Server	S,D	
4.3.2	M447621	Use strong cryptographic algorithms	S,D	
4.3.3	M447580	Requirements for SSH keys	S,D	
Services - NTP				
4.4.1	M140306	Time Synchronization	S,D	
4.4.2	M447886	Network Time Protocol Daemon	S,D	
Services - SNMP				
4.5.1	M840320	Secure SNMP Server	S,D	
Services - Mail Transfer Agents				
4.6.1	M402440	Secure Mail Transfer Agent Daemon	S,D	
Services - IMAP and POP3 Server				
4.7.1	M784009	Secure IMAP and POP3	S,D	
Services - Webserver				

Chapter No.	Measure No.	Measure	H/S/W flag	Done
4.8.1	M410802	Protecting Web Server	S,D	
Services - NFS and RPC				
4.9.1	M478100	Configure NFS	S,D	
Samba				
4.10.1	M602600	Secure Samba Server	S,D	
4.10.2	M830304	Configure Samba Server in Active Directory Environment	S,D	
4.10.3	M107290	Avoid the Samba Web Administration Tool (SWAT)	S,D	
Services - FTP				
4.11.1	M200290	Configure FTP Daemon	S,D	
4.11.2	M296020	Secure Anonymous FTP	S,D	
Services - X Server				
4.12.1	M420460	Restricting X Server Access	S,D	

Administrator

Date

Signature

References

- [1] Siemens GS IT ISEC, *Siemens Information Security Framework*, available at <http://intranet.siemens.com/ISECFramework>
- [2] Siemens GS IT ISEC, *Topic-Specific ISEC Policy: Access Control*, available at <https://inspire.siemens.com>
- [3] Siemens GS IT ISEC, *Topic-Specific ISEC Policy: Cryptography*, available at <https://inspire.siemens.com>
- [4] Siemens GS IT ISEC, *Topic-Specific ISEC Policy: Operations Security*, available at <https://inspire.siemens.com>
- [5] Siemens CERT, *Security Measure Plan for VMware vSphere 5*, available at https://www.cert.siemens.com/rules/policy/CERT_VMware_vSphere5_Measure_Plan.pdf
- [6] Siemens GM SEC, *Siemens Circular No. 156: "Risk-based Asset Classification and Protection Process"*, 23 September 2016, Version 1.1, available at https://circulars.siemens.com/documents/circulardownload.aspx?id=sc_156.pdf
- [7] Siemens CIT, *Siemens Circular No. 133: "Usage of Standard Platforms"*, 18 June 2010, Version 1.0, available at https://circulars.siemens.com/documents/circulardownload.aspx?id=sc_133.pdf